NOLVEX
INNOVATION CONNECTED

RESPONSE TO RFP-2026-SYS-003

Technical and Financial Proposal

Strategic Development & Engineering of Enterprise Software Platforms — **Combined Dual-System Development Package**

Track A — Unified Active Audit

Sub-50 ms semantic masking proxy, context-preserving tokenization and a WORM audit ledger that maps live AI traffic to ISO 42001, HIPAA, EU AI Act and SOC 2 controls.

Track B — Zero-Template Autonomous Operator

Layout-agnostic VLM extraction, calibrated confidence with closed-loop human review, Temporal durable orchestration and hybrid API / GUI write-back.

RFP reference	RFP-2026-SYS-003 — issued 20 October 2026 · response deadline 20 November 2026, 5:00 PM EST
Submitted to	Raphael Bosire, the Issuing Organization — bosire73@gmail.com
Submitted by	Nolvex — Suite 405, 4th Floor, 2129 Office Suites, 69 Muthithi Road, Westlands, Nairobi, Kenya
Authorised signatory	David Ngeiywa, Director — +254 714 985 264 — david@dta.co.ke
Proposal date	26 October 2026 · valid for 90 days (to 24 January 2027)
Pricing basis	Fixed price per RFP phase · Kenya Shillings (KES), VAT exclusive · USD equivalents at 1 USD = KES 129 for reference

1 Cover Letter

26 October 2026

Raphael Bosire
The Issuing Organization
bosire73@gmail.com

Re: RFP-2026-SYS-003 — Strategic Development & Engineering of Enterprise Software Platforms — Combined Dual-System Development Package

Dear Mr. Bosire,

Nolvex is pleased to submit the enclosed technical and financial proposal for the Combined Dual-System Development Package: Track A, the Automated AI & Data Compliance Platform ("Unified Active Audit"), and Track B, the Agentic AI Back-Office Processor ("Zero-Template Autonomous Operator"). We propose to architect, build, prove and hand over both platforms over the RFP's 24-week, six-phase life cycle, against milestones M1.1 to M6.3, for a **fixed professional-services price of KES 3,900,000 (approximately USD 30,233), VAT exclusive**. Single-track pricing (Track A: KES 1,800,000; Track B: KES 2,300,000) is given in Section 12 should you prefer to procure one system first.

We have read the RFP as a product thesis rather than a feature list. Its value lies in two things incumbents do not do: intervening in live AI data flows and turning every intervention into regulator-ready evidence; and processing documents nobody has templated while learning from each human correction. Our proposal is organised around proving exactly those differentiators:

- **Measurable, not aspirational.** Each differentiator carries an acceptance test the Issuing Organization can run: p99 masking latency under 50 ms at the proxy, evidenced by K6 at every phase gate; field-level extraction accuracy above 95% on a held-out benchmark set you control; and a demonstration that one reviewer correction changes the next extraction without engineering involvement (Section 2.2).
- **Engineered for the hard numbers.** A Rust hot path with a per-stage latency budget; a WORM ledger on S3 Object Lock in compliance mode with a hash chain and external timestamps; schema-guided vision-language extraction with calibrated per-field confidence; and Temporal durable execution for every document lifecycle (Section 5).
- **Transparent commercially.** A fixed price per phase, paid on milestone acceptance exactly as RFP §4 prescribes; an open-source-first stack with no embedded licence fees; itemised pass-through costs; and a predictable post-handover cost model, including a Year-1 total-cost view (Section 12).

Nolvex has also built a **working demonstration of both tracks** for this response; its screenshots are in Section 5.9, and we offer a live session on your own sample prompts and documents within ten business days of shortlisting (Section 7.3), so that the evaluation can rest on observed behaviour rather than claims.

This proposal is valid for 90 days from the date above. I am the authorised signatory and the single point of contact for all questions concerning it.

Yours sincerely,

David Ngeiywa
Director, Nolvex
+254 714 985 264 · david@dta.co.ke

Table of Contents

1. Cover Letter 2

2. Executive Summary 4

2.2 Three measurable commitments · 2.3 Response to the evaluation criteria · 2.4 Why Nolvex 5

3. Our Understanding of the Opportunity 7

4. Scope Summary 9

5. Technical Proposal 11

5.1 Track A — Unified Active Audit: solution architecture 11

5.2 Semantic tokenization in depth 12

5.3 WORM ledger and compliance generator in depth 14

5.4 Track B — Zero-Template Autonomous Operator: solution architecture 14

5.5 Zero-template extraction and calibrated confidence 15

5.6 Closed-loop HITL and active learning 16

5.7 Temporal state machine and hybrid execution engine 17

5.8 How each hard target will be met 18

5.9 User interface concept designs 22

5.10 Technology stack 27

6. Security and Compliance Approach 30

6.1 The regulatory landscape this platform must evidence (October 2026) 30

6.2 Framework alignment · 6.3 Data protection and residency · 6.4 Secrets · 6.5 Penetration testing · 6.6 Additional controls 31

7. Delivery Plan 33

7.2 24-week Gantt chart · 7.3 Proof-of-capability demonstration · 7.4 Governance and communication 34

8. Quality Assurance, CI/CD and Testing 36

9. Risk Register and Heat Map 38

10. Team Structure and Org Chart 40

11. Assumptions, Dependencies and Client Responsibilities 42

12. Financial Proposal 44

12.2 Fixed-price summary · 12.3 Phase payment schedule · 12.4 Effort breakdown 44

12.5 Pass-through costs · 12.6 Ongoing costs and SLA · 12.7 Year-1 total cost of ownership 45

12.8 Optional add-ons · 12.9 Payment terms · 12.10 Commercial terms 47

13. Appendices 49

A. Acceptance criteria per milestone 49

B. Glossary 50

C. Compliance control mapping 51

D. RFP requirements compliance checklist 52

E. Company details and references 53

F. Sample audit package (concept) 54

G. API contract excerpt 55

H. Sources and references 55

Figures: 1 Track A architecture · 2 Semantic tokenization example · 3 Ledger integrity chain · 4 Track B architecture · 5 Document lifecycle state machine · 6 Latency budget · 7–10 UI concept designs · 11 Gantt chart · 12 Risk heat map · 13 Delivery team · 14 Payment schedule · 15 Sample audit package.

Confidential —prepared for the Issuing Organization. ©2026 Nolvex.

2 Executive Summary

The Issuing Organization has specified two platforms whose value lies in doing what today's incumbents do not: intervening in live AI data flows and turning every intervention into regulator-ready evidence (Track A), and processing documents nobody has templated while learning from every human correction (Track B). Nolvex proposes to design, build, prove and hand over both as the Combined Dual-System Development Package, in 24 weeks, for a fixed price of **KES 3,900,000** (≈ USD 30,233) excluding VAT and pass-through costs, paid on milestone acceptance exactly as RFP §4 prescribes.

< 50 ms
p99 masking latency at the proxy — K6-evidenced at M2.1 and M5.3

> 95%
Field-level extraction accuracy on a client-held benchmark set

5,000 req/s
Track A UAT stress target; 7,500 req/s soak in acceptance

1,000 docs/hr
Track B UAT stress target; 2,000-document Locust run

24 wks
Six RFP phases, 18 milestones, fixed price, 15/20/20/20/15/10 payments

2.1 What we will deliver

Track A — Unified Active Audit

- A **Rust in-line proxy** that detects PII/PHI/PCI in streaming LLM prompts and responses and replaces each span with a **context-preserving semantic token**, so downstream models keep reasoning while the data never leaves your boundary (§5.1–5.2).
- A **WORM audit ledger**: Kafka → ClickHouse for query, S3 Object Lock (compliance mode) as the authoritative hash-chained record, with external timestamp anchoring (§5.3).
- A **one-click compliance generator** that maps every event to ISO 42001, HIPAA, EU AI Act and SOC 2 controls and exports audit packages as PDF and CSV (§5.3, Appendix F).
- Live connectors for AWS CloudTrail, Snowflake, OpenAI and Anthropic (M3.1).

Track B — Zero-Template Autonomous Operator

- A **schema-guided vision-language extraction core** for unformatted, handwritten and variable-layout documents, with per-field provenance and **calibrated confidence** (§5.4–5.5).
- A **Temporal.io state machine** holding each document's lifecycle durably across retries, timers and human review (§5.7).
- A **closed-loop HITL workbench** for fields below 95% confidence whose corrections flow back into exemplar memory, routing rules and thresholds automatically (§5.6, §5.9).
- A **hybrid execution engine**: HL7 FHIR R4 (Epic, Oracle Health/Cerner), NetSuite, SFTP, REST and SOAP adapters, with a computer-vision GUI agent as the fallback for legacy software (§5.7).

Both tracks share one platform layer: a multi-tenant admin portal with role-based access control, SAML 2.0 / Okta single sign-on and usage metering (M4.3); Terraform-provisioned Kubernetes on EKS or GKE with GitOps CI/CD (M1.3); SOC 2 and HIPAA audit-readiness evidence, an accredited penetration test with zero unresolved High or Critical findings, and K6/Locust benchmarks (M5.1–M5.3); production rollout, full source and documentation transfer with test coverage above 85%, training and an SLA handover (M6.1–M6.3).

Confidential —prepared for the Issuing Organization. ©2026 Nolvex.

2.2 Three measurable commitments against the 30% "differentiator realization" criterion

Differentiator (RFP §5)	What Nolvex commits to	How the Issuing Organization verifies it
Sub-50 ms data masking	p99 latency ≤ 50 ms for the masking stage measured at the proxy (upstream LLM time excluded), sustained at 5,000 req/s and soaked at 7,500 req/s, with a per-stage budget (§5.8.1) and a fail-closed policy on timeout.	K6 scripts and reports delivered at M2.1 (1,000 req/s in staging) and M5.3 (7,500 req/s, 30 minutes); Grafana latency histograms per connector; context-preservation benchmark report.
Zero-template VLM extraction	Field-level accuracy > 95% on a stratified, held-out benchmark set (≥ 300 labelled documents per class, including handwritten and poor scans) agreed at M1.1 and never used for prompt tuning; every field carries page and bounding-box provenance and a calibrated confidence score.	Evaluation-harness reports at M2.2, M4.1 and M5.3 with per-field and per-class accuracy, confusion analysis and calibration curves (expected calibration error reported).
Active-learning HITL loop	A reviewer correction, made once in the HITL workbench, measurably changes the next extraction of a similar document — through exemplar retrieval, routing rules and threshold re-calibration — with no engineer involved, and with the correction, model version and prompt hash recorded in the ledger.	Live demonstration at M4.1 using the client's documents; Playwright end-to-end test; harness delta report showing accuracy improvement after a batch of corrections.

> **Proof-of-capability demonstration (Section 7.3)**
>
> A working demonstration build of both tracks already exists; screenshots of it are in §5.9. Within ten business days of shortlisting, Nolvex will demonstrate it live, on sample prompts and documents supplied by the Issuing Organization: in-line masking with latency shown on a live histogram; template-free extraction of unseen documents, including handwritten samples; and a human correction changing the next result. No commitment is required from the Issuing Organization beyond providing the samples.

2.3 Response to the evaluation criteria

Criterion (RFP §5)	Weight	Where to look	What the evaluator will find
Technical competence & differentiator realization	30%	§2.2, §5.1–5.8, §7.3, App. A	Per-stage latency budget; token design with worked example; ledger integrity chain; extraction, confidence and active-learning mechanics; acceptance tests per milestone; live demonstration offer.
Industry track record	25%	§2.4, §10, App. E	Delivery model and single accountable lead; three reference projects with referees in Appendix E.

Criterion (RFP §5)	Weight	Where to look	What the evaluator will find
Commercial value & cost transparency	20%	§12.1–12.10	Fixed price per phase on the RFP's 15/20/20/20/15/10 schedule; effort basis by role; itemised pass-through costs; support tiers; Year-1 total-cost-of-ownership view; add-on price list.
Security posture & compliance preparedness	15%	§6, App. C, App. F	Current (October 2026) regulatory landscape; control-by-control mapping for ISO 42001, HIPAA, EU AI Act and SOC 2; data residency, secrets, supply-chain and penetration-testing approach; sample audit package.
Project execution plan	10%	§7–11	Phase plan aligned to RFP §3, Gantt with milestone acceptance points, CI/CD gates, scored risk register with owners, team structure, assumptions and dependencies with dates.

2.4 Why Nolvex

Accountability you can see

One named Director as signatory, architect and project lead; weekly written status, fortnightly steering, phase-gate demos; acceptance criteria written down for all 18 milestones before work starts (Appendix A).

No lock-in by design

Open-source-first stack with no licence fees embedded in the price; all deliverables, including prompts, schemas and control maps, assigned to the Issuing Organization; deployment in your own cloud account; SBOM-documented dependencies.

Evidence over assertion

Every hard target in the RFP has a measurement method, a tool and a milestone at which the number is delivered — and a live demonstration offer before contract.

Built to be audited

Both platforms are designed so that SOC 2, HIPAA and ISO 42001 evidence is a by-product of normal operation, not a quarterly scramble: the ledger that serves your customers also serves your auditors.

Nolvex does not hold SOC 2, HIPAA or ISO 42001 certifications itself and claims none; the deliverable is a system whose controls, documentation and evidence support the Issuing Organization's own audits (§6). Reference projects are listed in Appendix E.

3 Our Understanding of the Opportunity

The RFP's thesis is correct, and it is more urgent than it was when the incumbents it names were last evaluated. Below we restate the gap with current, sourced evidence (October 2026), sharpen it where the market has moved, and derive the design principles that shape Sections 5 and 6. Numbered references are listed in Appendix H.

3.1 The market gap, in evidence

Track A — compliance platforms monitor; guardrails mask; nobody does both with immutable, control-mapped evidence

Segment	Where the incumbents are today	What they still do not do
GRC / continuous control monitoring (Vanta, Drata)	Vanta reports $300M ARR and 16,000 customers (Apr 2026)[1] and released "AI Governance" in early access on 30 Jul 2026 — an agent inventory with ISO 42001 and EU AI Act impact assessments[2]; Forrester rates it strongest in continuous controls monitoring (Q2 2026)[3]. Drata's "AI Agent Governance" reached limited availability on 4 Aug 2026 with an MCP proxy that gates agent tool calls and a tamper-evident evidence feed, Anthropic-first[4][5].	Neither documents content-level intervention — detecting and tokenising PII, PHI or PCI inside prompt and response payloads — nor a latency-bounded in-line data path, nor write-once storage. Their newest products govern *actions* (which tool an agent may call); the RFP's Track A governs *data*. The gap has narrowed from "no real-time intervention" to "no content-level intervention with WORM evidence", and that is precisely where Track A sits.
LLM data-protection and guardrail tools (Protecto and peers)	Protecto offers reversible, format-preserving tokenisation and logs every scan, mask and unmask event with PDF/CSV export[6]. Lakera publishes a p95 under 20 ms — for prompt-injection screening, not tokenisation[7]. Nightfall added an MCP gateway in Sep 2026[10]; AWS Bedrock Guardrails filters 31 PII types but ignores tool-call payloads and publishes no latency commitment[11].	No vendor publishes a sub-50 ms tokenisation latency, and none produces audit packages mapped control-by-control to ISO 42001, HIPAA, the EU AI Act and SOC 2 from per-event, immutable records[6][12]. Protecto's exports are event logs, not control evidence. The segment is also consolidating into platform vendors — Protect AI and Portkey into Palo Alto Networks, Lakera into Check Point, Prompt Security into SentinelOne[8][9] — which makes a model- and gateway-agnostic product more valuable to buyers, not less.

Track B — document processing still carries template and taxonomy debt, and agentic automation is failing on controls

Segment	Where the incumbents are today	What they still do not do
IDP (ABBYY, UiPath, Hyperscience, Rossum)	ABBYY Vantage's unit of work is a "skill", defined in its own documentation as "an AI model trained to handle one document type"; its Oct 2026 Phoenix Plus zero-shot models still sit inside that skill architecture[13]. UiPath Document Understanding requires a schema per document type and "at least 150 documents for each document type" to train, with generative extraction dependent on a third-party LLM[14]. Rossum was acquired by Coupa in May 2026[17].	Forrester's Q2 2026 evaluation of document mining platforms finds accuracy "often starts around 60%-plus and improves with tuning", that reaching an MVP takes about six months, and that human review "remains essential"[15]. None of the incumbents publishes calibrated confidence with a guaranteed error rate on auto-approved fields, and none closes the loop from a reviewer's correction to the next extraction without a retraining cycle. The layout-agnostic, schema-driven, self-correcting operator the RFP specifies is the product the market's own documentation says it lacks.
RPA and "agentic" automation	UiPath's 2026 roadmap moves to agent orchestration (Maestro); Tungsten embeds agents in TotalAgility. Gartner predicts that more than 40% of agentic AI projects will be cancelled by the end of 2027, citing inadequate risk controls and unclear value[16].	UI-driven automation remains brittle to interface change and un-auditable by design. A processor whose every action is durable (Temporal), verified by read-back, and recorded in an immutable ledger is the direct answer to the risk-control failure Gartner describes.

Market context: Gartner forecasts spending on securing AI at almost USD 5 billion in 2027[18] and AI governance platforms exceeding USD 1 billion by 2030[19]; independent estimates place intelligent document processing at USD 3.6–4.4 billion in 2026 with 24–33% annual growth[20].

3.2 What category leadership requires

Track A — "Intervene on content, prove it with evidence nobody can edit"

- **Content-level, in-line tokenisation** with a published, independently reproducible p99 — the number no incumbent publishes.
- **A WORM ledger** whose authoritative copy cannot be altered by the operator, the vendor or a cloud root account, verified by a tool the auditor can run themselves.
- **Per-event control mapping** across ISO 42001, HIPAA, EU AI Act and SOC 2, exported as a package an auditor can accept — the combination no product ships today[12].
- **Model- and gateway-agnostic** by design, so consolidation among guardrail vendors becomes the client's opportunity rather than its risk.

Track B — "Schema, not template; calibrated confidence, not guesswork; learn from every correction"

- **Schema-driven extraction** that needs a target data definition and zero layout knowledge — removing the "skill per document type" cost line.
- **Calibrated confidence** so that "95%" is a measured probability with a reported error bound on auto-approved fields, not a verbalised score.
- **A closed loop** in which a reviewer's correction changes the next extraction the same day, through exemplar retrieval and routing, with no retraining cycle.
- **Durable, verified, audited execution** — Temporal orchestration, read-back verification and ledger evidence — the controls whose absence is cancelling agentic projects.

3.3 Design principles that follow

1. **Deterministic first, models second, on the hot path.** Structured identifiers are resolved by compiled automata in microseconds; statistical models handle only what is ambiguous, inside a hard deadline, with a fail-closed fallback (§5.2).
2. **Evidence is a by-product of operation.** The same event that drives the product (a masking decision, a review action, a write-back) is the compliance evidence — never a separate collection job (§5.3).
3. **Every number is defined so it can be audited.** Latency is p99 at a named measurement point; accuracy is field-level on a held-out set the client controls; confidence is calibrated and its error reported (§5.5, §5.8).
4. **Human oversight is a feature, not a fallback.** The HITL workbench is designed for throughput and produces the human-oversight evidence ISO 42001 and EU AI Act Article 14 require (§5.6, §6).
5. **No lock-in.** Open-source-first components, open-weight model fallbacks, provider-agnostic routing, and full IP assignment to the Issuing Organization (§5.10, §12.10).
6. **Trust nobody, including Nolvex.** The ledger verifier is open source and runs without access to Nolvex systems; the benchmark test split is held by the client (§5.3, §5.5).

Confidential —prepared for the Issuing Organization. ©2026 Nolvex.

4 Scope Summary

This proposal responds to the Combined Dual-System Development Package in RFP §1 and §2. Both systems are designed, built, tested, documented and deployed to the Issuing Organization's production cloud over the 24-week programme in RFP §3, together with the shared platform services (multi-tenant admin portal, RBAC, SSO) that RFP §3 Phase 4 requires for both tracks. Each item references the proposal section that describes it and the milestone at which it is accepted.

4.1 Track A — Unified Active Audit RFP §2, Key Technical Specs — Track A

RFP specification	Nolvex scope	Section · milestone
Sub-50 ms proxy engine	Rust microservice (Tokio/Hyper) on the request path that evaluates and masks streaming LLM prompt and response payloads in-line without breaking semantic context; deterministic detection first, a Python semantic service for ambiguous spans within the latency budget; stream-aware re-hydration.	§5.1, §5.8.1 · M2.1
Semantic tokenization	PII/PHI/PCI replaced with tokens that carry entity type, semantic role and a quantised context vector, deterministic per tenant so references stay consistent across a conversation; reversible only for authorised consumers through a KMS-encrypted vault.	§5.2 · M2.1
Continuous active audit ledger (WORM)	Append-only event store: Kafka backbone, ClickHouse query tier, S3 Object Lock in compliance mode as the authoritative record; SHA-256 hash chain with periodic external timestamp anchoring; retention and legal-hold API.	§5.3 · M4.2
Audit export mapped to controls	Compliance generator mapping events to ISO 42001, HIPAA, EU AI Act and SOC 2 controls; one-click PDF/CSV audit packages per framework, tenant and period, with chain verification embedded in each package.	§5.3, App. C, App. F · M4.2
Live connectors	AWS CloudTrail (log ingestion), Snowflake (SQL-over-HTTP with result masking), OpenAI and Anthropic (prompt/response dispatch incl. streaming), each a Rust crate implementing a common connector trait with contract tests.	§5.1 · M3.1
Targets	p99 masking latency < 50 ms; 5,000 req/s under UAT stress (7,500 req/s soak); test coverage > 85%.	§5.8 · M2.1, M5.3, M6.2

4.2 Track B — Zero-Template Autonomous Operator RFP §2, Key Technical Specs — Track B

RFP specification	Nolvex scope	Section · milestone
Zero-template VLM extraction core	Multimodal pipeline for unformatted, handwritten and variable-layout documents (e.g. freight bills of lading, medical prior-authorisations) guided only by a target schema; document-class auto-detection; exemplar retrieval; OCR cross-check; per-field provenance.	§5.4–5.5 · M2.2

RFP specification	Nolvex scope	Section · milestone
Temporal state machine & retry logic	One durable Temporal.io workflow per document: idempotent activities, exponential back-off retries, review-SLA timers, signals for human decisions, versioned workflow code, Redis-backed intake queue for bursts.	§5.7 · M2.3
Closed-loop HITL & active learning	React/Vite exception-handling workbench for fields below 95% confidence: side-by-side validation, annotation, keyboard-first correction, single-click retrain that writes corrections to exemplar memory, routing rules and thresholds.	§5.6, §5.9 · M4.1
Hybrid execution engine	Write-back adapters for Epic and Oracle Health (Cerner) via HL7 FHIR R4, NetSuite SuiteTalk REST, SFTP (PGP option), generic REST and SOAP, database sync; computer-vision GUI agent (Playwright / desktop runner) as the fallback where no API exists, with screenshot verification and allow-lists.	§5.7 · M3.2, M3.3
Targets	Field-level accuracy > 95%; 1,000 documents per hour under UAT stress (2,000-document run); test coverage > 85%.	§5.8 · M2.2, M5.3, M6.2

4.3 Shared platform and programme deliverables Both tracks

- **Phase 1:** System Architecture Document; OpenAPI 3.0 and gRPC schema contracts; PostgreSQL, ClickHouse and Redis data models; Kafka topologies; Temporal state-machine blueprints; modular Terraform for EKS/GKE; CI/CD to staging (M1.1–M1.3).
- **Phase 4:** Multi-tenant admin and tenant-management portal with RBAC, SAML 2.0 / Okta SSO and usage-based billing metrics (M4.3).
- **Phase 5:** SOC 2 Type II and HIPAA audit-readiness verification with evidence index; accredited third-party penetration test with signed remediation and zero unresolved High/Critical findings; K6/Locust load benchmarks; UAT sign-off (M5.1–M5.3).
- **Phase 6:** High-availability production deployment behind production API gateways; complete source, IaC and build repositories with coverage > 85%; runbooks, API developer documentation and SDK references, end-user and administrator manuals; operational training; SLA maintenance contract with Tier 1–3 response times (M6.1–M6.3).

4.4 Hard targets

< 50 ms
Semantic masking latency, p99 at the proxy, Track A — §5.8.1

> 95%
Field-level extraction accuracy on held-out set, Track B — §5.8.2

5,000 req/s
UAT stress throughput, Track A — §5.8.3

1,000 docs/hr
UAT stress throughput, Track B — §5.8.3

> 85%
Unit and integration test coverage, both tracks — §5.8.4, §8

Out of scope unless added by change request (§12.10) or add-on (§12.8): connectors and adapters beyond those named in RFP §3; more than one legacy application for the GUI agent; document classes beyond those fixed at M1.1; invoicing or payment-gateway integration behind the usage metrics (A-12); Nolvex-hosted operation of client data (A-7).

Confidential —prepared for the Issuing Organization. ©2026 Nolvex.

5 Technical Proposal

Section 5 describes how each system is built, why the design meets the RFP's hard numbers, and what the Issuing Organization's users will see. Sections 5.1–5.3 cover Track A, 5.4–5.7 cover Track B, 5.8 maps every hard target to a measurement, 5.9 presents interface concept designs and 5.10 the technology stack.

5.1 Track A — Unified Active Audit: solution architecture Track A

Track A places a Rust proxy on the request path between client workloads and the connected AI and data services. Each inbound payload passes through a semantic masker that detects PII, PHI and PCI and replaces every sensitive span with a context-preserving token before real-time dispatch to the model; on the response path, tokens echoed by the model are re-hydrated for authorised consumers only. Every decision is emitted as an audit event to Kafka and persisted in a WORM ledger — ClickHouse for query, S3 Object Lock for immutability — from which the compliance generator produces audit packages mapped to ISO 42001, HIPAA, EU AI Act and SOC 2 controls. The hot path never waits for persistence.

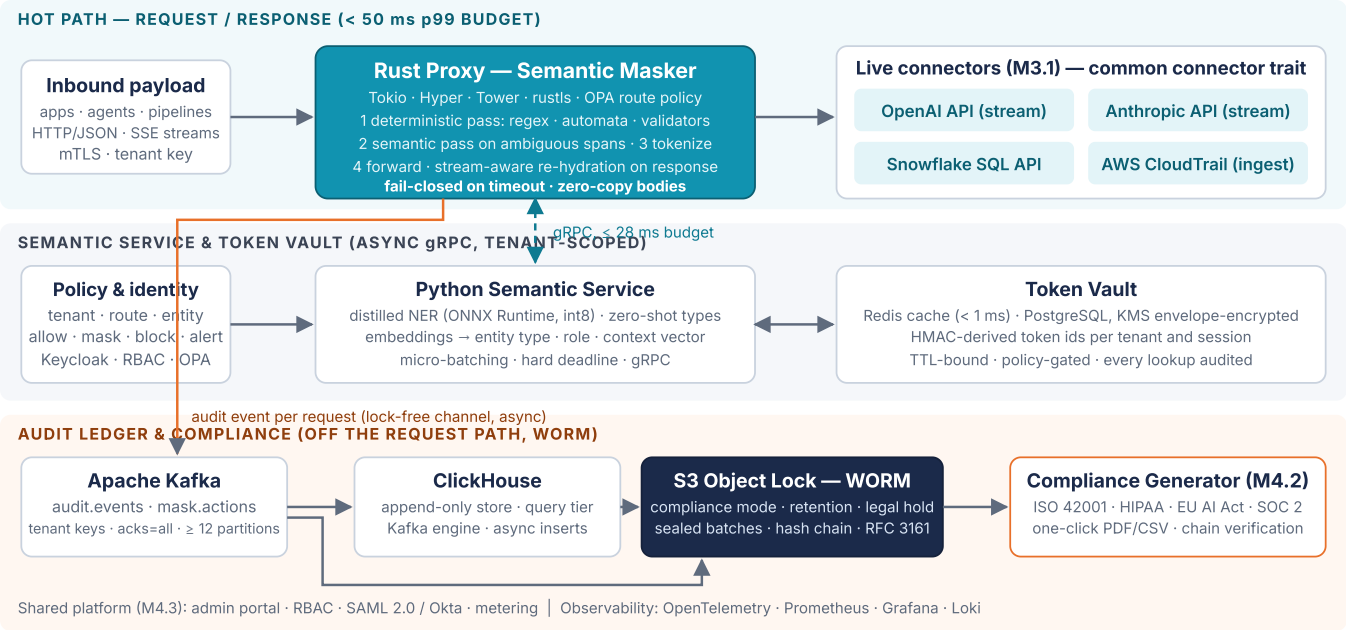


Figure 1 — Track A: Unified Active Audit architecture. The proxy resolves most spans deterministically and consults the semantic service only for ambiguous spans inside a hard deadline; audit events leave the hot path through a lock-free channel. The S3 Object Lock ledger, not ClickHouse, is the authoritative record.

Component	Responsibility and design decisions
Rust proxy / semantic masker	Terminates TLS, authenticates tenant and caller, evaluates the route policy, runs the deterministic detection pass (compiled RegexSet and Aho-Corasick automata, format validators, tenant dictionaries), calls the semantic service only for spans the deterministic pass marks ambiguous, substitutes context-preserving tokens, forwards to the connector, re-hydrates tokens on the response path for authorised consumers and emits an audit event. Stream-aware for chunked LLM responses (§5.2). Stateless; scales horizontally behind a network load balancer.

Component	Responsibility and design decisions
Python semantic service	Distilled transformer NER served through ONNX Runtime (int8) plus a zero-shot entity-type head so tenants can add entity types (e.g. "policy number", "DEA number") without retraining; a small contextual embedding model derives each span's semantic role (patient, provider, payer, cardholder) and a quantised context vector used in the token. Micro-batching with a hard deadline; if the deadline is missed the proxy applies the fail-closed policy for that span.
Token vault	Token-to-value mappings held in PostgreSQL with envelope encryption under AWS KMS and a Redis cache for the sub-millisecond hit path. Token identifiers are derived with an HMAC under a per-tenant key so the same value yields the same token within a session (consistent references) but different tokens across sessions (unlinkable). Every lookup is itself an audited event.
Kafka	Durable, ordered backbone; topics per event class with tenant-keyed partitions; `acks=all`; decouples the hot path from persistence and lets ClickHouse and the ledger writer consume independently.
WORM ledger (ClickHouse + S3 Object Lock)	ClickHouse ingests through Kafka engine tables for interactive query and dashboards; a ledger writer seals batches, computes a SHA-256 hash chain with Merkle roots and writes them to S3 with Object Lock in compliance mode under a tenant-defined retention. Compliance mode cannot be shortened or deleted by any principal, including the root account, until retention expires (§5.3).
Compliance generator / audit export	Maps each event class to controls in ISO 42001, HIPAA, EU AI Act and SOC 2 (Appendix C), produces one-click PDF and CSV packages per framework, tenant and period, verifies the hash chain before export and embeds the verification result in the package (Appendix F); retention and legal-hold API.
Connectors (M3.1)	OpenAI and Anthropic (prompt/response dispatch, streaming, tool-call payload masking); Snowflake (SQL-over-HTTP with result-set masking and query logging); AWS CloudTrail (log ingestion into the ledger with event-class mapping). Each is a Rust crate implementing a common connector trait with contract tests against recorded fixtures.

5.2 Semantic tokenization in depth Track A

Masking that breaks the model's ability to reason is not useful; the RFP's phrase "context-preserving" is the design constraint. Nolvex's token carries three things the model needs and nothing it must not have: the **entity type**, its **semantic role** in the text and a **stable identifier** so that references stay consistent throughout a conversation.

① INBOUND PROMPT (as received)

```
Summarise the case. Patient Maria Okonkwo, DOB 03/14/1961,
MRN 8841-2290, was seen by Dr. Alan Reyes on 2026-09-30
for atrial fibrillation. Card ending 4242 4242 4242 4242
was charged $180. Call her on +1 617 555 0142.
```

② MASKED PROMPT (what the LLM sees)

```
Summarise the case. Patient ⟦PERSON_1|patient⟧, DOB ⟦DATE_1|dob⟧,
MRN ⟦MRN_1⟧, was seen by ⟦PERSON_2|provider⟧ on ⟦DATE_2|visit⟧
for atrial fibrillation. Card ending ⟦PAN_1⟧
was charged $180. Call her on ⟦PHONE_1⟧.
```

③ MODEL RESPONSE (tokens echoed)

```
⟦PERSON_1|patient⟧ (⟦DATE_1|dob⟧) was seen by
⟦PERSON_2|provider⟧ on ⟦DATE_2|visit⟧ for atrial
fibrillation; a ⟦PAN_1⟧ payment of $180 was taken.
Follow up with ⟦PERSON_1|patient⟧ at ⟦PHONE_1⟧.
```

④ RE-HYDRATED RESPONSE (authorised consumer only)

```
Maria Okonkwo (03/14/1961) was seen by
Dr. Alan Reyes on 2026-09-30 for atrial
fibrillation; a card payment of $180 was taken.
Follow up with Maria Okonkwo at +1 617 555 0142.
```

Figure 2 — Semantic tokenization, worked example. Clinical content ("atrial fibrillation", "$180") is preserved because it is not an identifier; identifiers are replaced by typed, role-tagged, session-consistent tokens so the model can still resolve "her" to the patient. Unauthorised consumers receive the tokenised response; the card number is never re-hydrated (PCI policy: irreversible). Names are illustrative.

Detection tiers

1. **Deterministic (≤ 5 ms).** Compiled RegexSet and Aho-Corasick automata for structured identifiers — card numbers with Luhn validation, SSN and ITIN rules, NPI check digits, MRN patterns per tenant, IBAN, e-mail, phone, dates, IP and device identifiers — plus tenant dictionaries (staff names, locations). Resolves the majority of PCI and structured PHI without any model call.
2. **Statistical NER (≤ 20 ms).** A distilled transformer served through ONNX Runtime for PERSON, ORGANIZATION, LOCATION, DATE and health-specific entities, with a zero-shot entity head so tenants can declare new entity types in configuration. Only spans the deterministic tier marks ambiguous (free-text names, addresses) reach this tier.
3. **Contextual embedding (≤ 8 ms, same call).** Each detected span is embedded with its surrounding window; nearest-prototype matching assigns the semantic role (patient, provider, payer, guarantor, cardholder) and a quantised context vector that is encoded into the token for downstream disambiguation. The embedding also catches variants the regex tier misses (nicknames, transliterations).

Token design and reversibility

- **Format.** `⟦TYPE_n|role⟧`, with *n* assigned in order of first appearance within the session and derived from an HMAC of the canonical value under a per-tenant KMS key, so the same person is always `PERSON_1` in that conversation, pronouns resolve, and tokens from different sessions cannot be linked.
- **Format-preserving options per entity type**, configured per tenant: dates shifted by a consistent per-session offset (clinical intervals stay correct), ages bucketed, ZIP codes truncated to three digits in line with the HIPAA Safe Harbor method, amounts kept.
- **Reversibility is a policy, not a default.** PCI primary account numbers are tokenised irreversibly; PHI tokens are reversible only for consumers whose identity and purpose the route policy authorises; re-hydration events are written to the ledger with the consumer identity.
- **Streaming.** Response chunks are scanned with a sliding window; a token that may straddle a chunk boundary is held back (at most the length of a token) until the boundary is resolved, so first-byte latency stays inside the budget and partial tokens are never emitted.

- **Fail-closed.** If the semantic tier misses its deadline, the route policy decides per entity class: redact the ambiguous span, or reject the request; the choice and the timeout are recorded.

Proving context preservation. At M2.1 Nolvex delivers a paired-prompt benchmark: the same tasks are run on raw and masked inputs across the client-approved models; structured tasks are scored by exact match and free-text tasks by an LLM judge for answer equivalence. The acceptance target is ≥ 97% equivalence on the agreed task set, reported with the K6 latency results.

5.3 WORM ledger and compliance generator in depth Track A

The ledger exists to let an auditor answer "what happened, in what order, and can I trust the record?" without trusting the operator. Three properties deliver that: the ledger never stores secrets, the authoritative copy cannot be altered by anyone, and any alteration or gap is detectable by a verifier that does not need Nolvex.

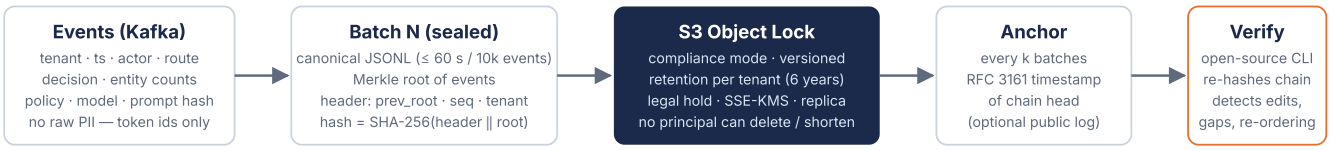


Figure 3 — Ledger integrity chain. Each sealed batch commits to the previous one; Object Lock compliance mode makes the stored batches immutable; periodic external timestamps prove the chain existed at a point in time; a stand-alone verifier lets the auditor check all of it without trusting the operator.

Compliance generator

- **Control map as versioned data.** Each event class (masking decision, re-hydration, policy change, model version change, connector call, access review, backup test, incident) maps to one or more controls in ISO/IEC 42001 Annex A, HIPAA Security Rule §164.308–316, SOC 2 Trust Services Criteria and EU AI Act Articles 9–15. The map is stored in PostgreSQL, editable by the client's compliance owner in the ledger UI, and every change is itself an event. Appendix C shows a sample; the full map is delivered at M1.1.
- **One-click packages.** For a framework, tenant and period the generator produces a PDF (cover and attestation page, control coverage matrix, evidence samples per control, exceptions and open items, chain verification result, model and policy inventory) and CSV extracts for the auditor's own tooling. A concept layout is in Appendix F.
- **Operational evidence, continuously.** Because evidence is derived from the ledger as events occur, a SOC 2 Type II observation period or an ISO 42001 surveillance audit can be answered for any window after go-live, not reconstructed.
- **Retention and legal hold.** Retention per tenant and framework (HIPAA documentation retention of six years is the default for PHI-related events); legal-hold API freezes batches beyond retention; deletion after retention is itself an audited, scheduled operation.

5.4 Track B — Zero-Template Autonomous Operator: solution architecture Track B

Track B ingests unstructured documents, extracts structured data with a vision-language model guided only by a target schema (no layout templates), scores every field with a calibrated confidence, routes anything below 95% to the human-in-the-loop workbench, and writes approved records to the system of record through an API adapter or, where none exists, a computer-vision GUI agent. Temporal.io holds each document's lifecycle durably across retries and human-review waits. Reviewer corrections are written back into exemplar memory, routing

rules and thresholds so that subsequent similar documents are extracted and routed more accurately — the closed loop the RFP asks for.

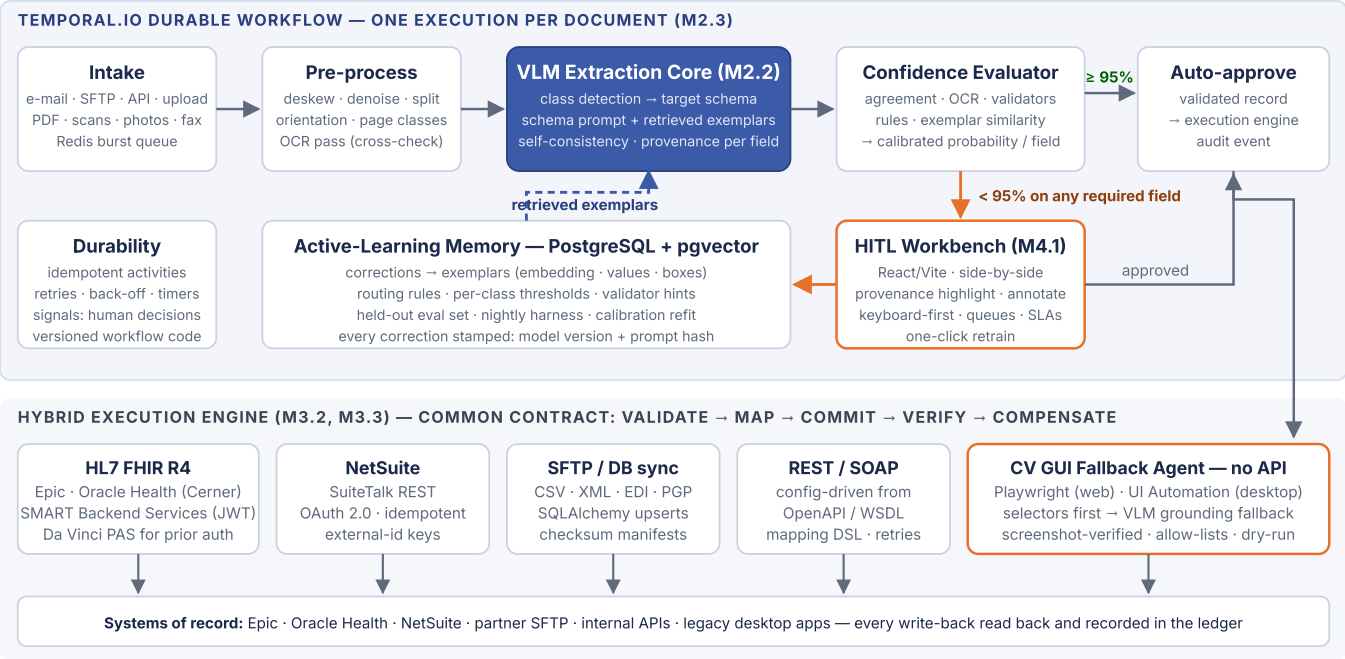


Figure 4 — Track B: Zero-Template Autonomous Operator architecture (RFP §2 Track B flow). The confidence evaluator is the gate: fields at or above 95% calibrated confidence auto-approve, anything lower goes to the workbench, and every correction feeds the memory that the extraction core reads on the next document.

5.5 Zero-template extraction and calibrated confidence Track B

Extraction without templates

1. **Document-class detection.** The VLM classifies each page set against the client's class catalogue (e.g. freight bill of lading, prior-authorisation request, supporting clinical notes) zero-shot; unknown classes route to the workbench for a one-time schema assignment rather than failing.
2. **Schema-guided prompting.** Each class has a target JSON Schema (fields, types, enumerations, required flags, cross-field rules) defined with the client at M1.1. The schema, not a layout, drives the prompt; the model is asked to return a typed object with, for every field, the page and bounding box it was read from. Structured-output decoding guarantees schema-valid JSON.
3. **Exemplar retrieval.** Before extraction, the page embedding is matched (pgvector, HNSW) against the active-learning memory; the nearest previously-corrected documents are included as few-shot exemplars. This is how one correction improves the next similar document without any model retraining.
4. **OCR cross-check and self-consistency.** Numeric and identifier fields (totals, dates, NPI, member IDs, container numbers) are cross-checked against an independent OCR pass; critical fields are sampled multiple times and must agree. Disagreement lowers confidence rather than silently picking an answer.
5. **Handwriting.** The VLM reads handwritten content directly; because OCR agreement is weaker on handwriting, the calibration model learns to weight it accordingly, so handwritten fields start with more human review and need less as exemplars accumulate.
6. **Validation.** Business rules from the schema (line items reconcile to totals, dates in range, codes in reference lists such as ICD-10, CPT, HCPCS, UN/LOCODE) run before scoring; a rule failure is a strong negative feature.

Calibrated confidence — why "95%" must mean 95%

A model's verbalised confidence is not a probability; using it as one would make the RFP's 95% threshold meaningless. Nolvex therefore computes a **calibrated probability per field** from observable features — agreement across sampled extractions, agreement with OCR, validator and business-rule outcomes, similarity to retrieved exemplars, document-quality metrics and, where the model exposes them, token log-probabilities — fitted with isotonic regression on the held-out calibration split of the benchmark set. The 95% gate is applied to that calibrated probability. Reported metrics include per-class accuracy, auto-approval rate, precision of auto-approved fields and expected calibration error (target ≤ 0.05), re-fitted nightly from reviewer outcomes so that drift in document mix or model behaviour is caught by the harness, not by customers.

> **Accuracy, defined so it can be audited**
>
> Field-level exact-match accuracy after normalisation (whitespace, case, date and number formats) across required fields on a stratified benchmark of at least 300 labelled documents per class, split 60/20/20 into tuning, calibration and held-out test; the test split is never used for prompt tuning, exemplar selection or calibration. The RFP's "> 95% accuracy on unformatted documents" is measured on that held-out split at M2.2 and re-validated at M4.1 and M5.3.

5.6 Closed-loop HITL and active learning Track B

The workbench (concept design in §5.9, Figure 7) is where the RFP's "active learning" becomes mechanical rather than aspirational. A reviewer sees the document and the extracted fields side by side, with each low-confidence field highlighted at its source location; they correct, annotate or approve with the keyboard; and one action — "approve and retrain" — triggers the feedback loop below.

Feedback channel	What is written back	Effect on the next document
Exemplar memory	The corrected document (page embedding, final field values, bounding boxes, reviewer notes) is stored as a retrievable exemplar, stamped with model version and prompt hash.	Similar layouts retrieve the exemplar as a few-shot example; the same mistake is not repeated.
Routing rules	Per-class statistics update: which prompt variant, model or pre-processing profile yields the best accuracy for that class and quality band.	Documents of that class are routed to the best-performing configuration automatically.
Threshold re-calibration	Reviewer outcomes (accepted vs corrected) become labels for the calibration model; nightly re-fit per class.	The 95% gate tracks real-world precision; auto-approval rate rises as the loop matures.
Validator suggestions	Repeated corrections of the same shape (e.g. a date format, a code list) are surfaced as proposed rules for the client's analyst to accept.	Systematic errors are caught deterministically rather than by review.
Evaluation set growth	A sampled fraction of corrected documents is added to the benchmark (never to the held-out test split).	The nightly harness measures real production distribution, not only the original sample.

- **Reviewer quality.** Golden documents with known answers are injected into queues at a low rate; reviewer agreement and golden accuracy are reported in the admin console; two-person review can be required per class.

- **Queues and SLAs.** Priority by business deadline (e.g. prior-authorisation decision windows), skill-based assignment, SLA timers held by Temporal, escalation on breach.
- **Auditability.** Every review action is an event in the Track A ledger with reviewer identity, before/after values and timing — which is also the human-oversight evidence ISO 42001 and EU AI Act Article 14 ask for.
- **Optional fine-tuning.** Once corrections per class exceed a few thousand, supervised fine-tuning (LoRA) of an open-weight VLM in the client's cloud becomes worthwhile; it is available as an add-on (§12.8) and is not required to meet the RFP targets.

5.7 Temporal state machine and hybrid execution engine Track B

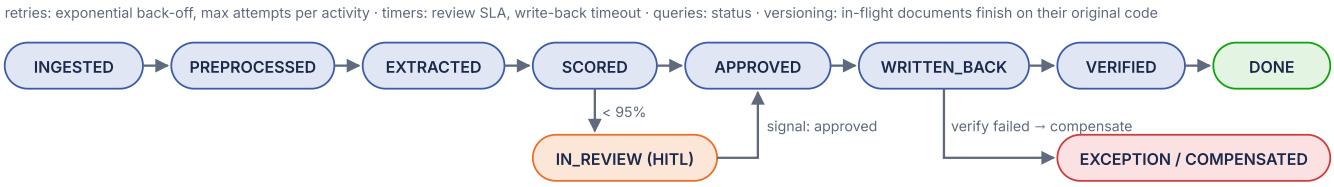


Figure 5 — Document lifecycle state machine (Temporal workflow). Each transition is a durable activity with its own retry policy; human review is a signal-awaited state with an SLA timer; a failed read-back verification runs the adapter's compensation path and parks the document in the exception queue.

- **One workflow per document**, with page-level child activities for parallelism; idempotent activities keyed by document and attempt so retries never double-write; worker pools sized per activity type (CPU for pre-processing, API-bound for VLM calls, I/O-bound for adapters).
- **Redis execution queue.** Intake bursts (e.g. a morning SFTP drop of thousands of files) are absorbed by a Redis-backed queue that releases work into Temporal at the configured rate, protecting VLM API quotas and keeping the 1,000 docs/hour throughput steady rather than spiky.
- **Deployment.** Self-hosted Temporal on Kubernetes with PostgreSQL persistence in the client's account; Temporal Cloud is available as a pass-through option where the client prefers managed operation.

Hybrid execution engine — write-back adapters (M3.2)

Every adapter implements one contract — *validate* → *map* → *commit* → *verify* → *compensate* — so that the workflow treats a FHIR server, an ERP and a legacy screen identically: it only ever asks "did the record land, and can I read it back?"

Target	Approach	Realities designed for
Epic and Oracle Health (Cerner) — HL7 FHIR R4	SMART Backend Services authorisation (client-credentials with a signed JWT against the registered key); FHIR R4 resources inside each vendor's documented write surface — on Epic, DocumentReference create/update, Observation (vitals/flowsheets) create, MedicationRequest/ServiceRequest update for prior authorisation, and Claim `$submit` / `$inquire` with `$submit-attachment` for Da Vinci PAS; on Oracle Health, POST/PUT on DocumentReference and system-scope writes on Observation, Condition, AllergyIntolerance, Appointment and MedicationRequest[69][70]; conditional create with client-generated identifiers for idempotency; read-back verification.	Every write is enabled per resource, per customer: Epic requires the health system's open.epic subscription and a client-record download per environment, Oracle Health requires tenant provisioning through its developer programme[69][70]. Registrations are started in week 1 (D-5); resource-level write support is confirmed in the sandbox at M1.1 and the adapter is scoped to what the client's instance permits (A-2). Prior-authorisation submission to payers follows the HL7 Da Vinci PAS profile that CMS recommends for the FHIR Prior Authorization APIs due 1 January 2027 (§6.1).
NetSuite	SuiteTalk REST record and query (SuiteQL) services with OAuth 2.0 client-credentials (certificate-based machine-to-machine) — not token-based authentication, which NetSuite closes to new integrations from release 2027.1, and not SOAP, which is being sunset[73]; external-id keys for idempotent upserts; transformation rules in a declarative mapping DSL; sandbox-first testing.	Custom fields and record types differ per account; the mapping DSL is client-editable without code changes.
SFTP and database sync	SFTP drops with checksum manifests and optional PGP; database upserts through SQLAlchemy with explicit transaction boundaries.	Partner file specifications (CSV, XML, EDI) change; schema versioning per partner.
Generic REST and SOAP	Adapters generated from OpenAPI and WSDL definitions, with the same mapping DSL, retry and verification stages.	Authentication schemes vary; secrets are injected from Vault / Secrets Manager (§6.4).

Computer-vision GUI fallback agent (M3.3)

- **Deterministic first, vision second.** Where the target is a web application, recorded Playwright flows using accessibility roles and stable selectors execute the common path; the vision-language model is invoked only to ground an element when selectors fail (set-of-marks screenshot prompting) or to confirm state. For desktop applications a Windows runner uses the UI Automation tree before falling back to pixel-level control.
- **Every action verified.** Each step is followed by a screenshot assertion of the expected state; the final record is read back from the screen and compared with the approved data before the workflow marks the document written.
- **Guard-rails.** Allow-listed applications, screens and fields; dry-run mode that produces an action plan without executing; change detection (layout drift beyond a threshold) that diverts the document to the exception queue rather than guessing; full screen recording attached to the ledger event.

5.8 How each hard target will be met Both tracks

Each RFP target below has a definition, a measurement method, a tool, a milestone at which the number is delivered, and the external evidence that makes the design credible before Nolvex has measured anything. Where public evidence does not support a claim, we say so and show how the design still meets the RFP's intent.

5.8.1 Sub-50 ms semantic masking (Track A, M2.1)

The target is a **p99 of 50 ms measured at the proxy for the masking stage**, excluding upstream LLM time, under the RFP's 5,000 req/s load. The budget is allocated per stage and enforced by nightly K6 runs from Phase 2.

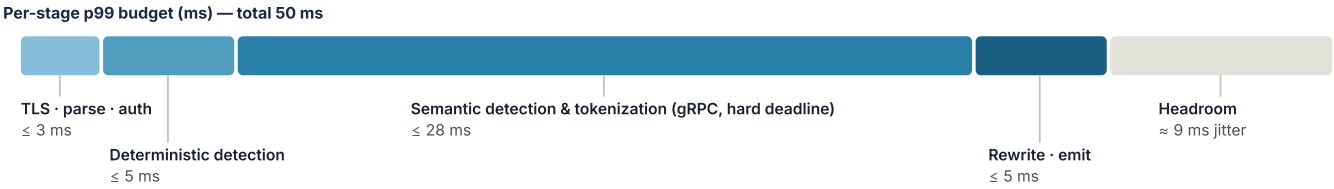


Figure 6 — Latency budget by stage. Audit emission is not on the path at all; it leaves through a lock-free channel after the response is forwarded.

Stage	Budget (p99)	Technique
TLS, parsing, tenant auth	≤ 3 ms	Tokio/Hyper async runtime; zero-copy bodies; cached authorisation decisions; connection pooling to connectors.
Deterministic detection	≤ 5 ms	Compiled RegexSet / Aho-Corasick; format validators (Luhn, SSN, NPI, IBAN, MRN patterns); dictionary tries. Resolves most PCI and structured PHI without a model call.
Semantic detection and tokenization	≤ 28 ms	Distilled token-classification NER (int8, ONNX Runtime) and a small embedding model served over gRPC with micro-batching; Redis token-cache hit path < 1 ms; hard deadline with policy-defined fail-closed behaviour. Zero-shot entity types for tenant-defined classes run on a GPU-served replica under the same deadline.
Rewrite and emit	≤ 5 ms	In-place span replacement; audit event handed to a lock-free channel and flushed to Kafka asynchronously, never on the request path.
Headroom	≈ 9 ms	Scheduling jitter and network variance; CPU requests sized to avoid CFS throttling, which is the usual cause of p99 cliffs in containerised proxies.

Why this budget is credible — independent evidence

- Presidio-class detection (regex, checksums and a spaCy NER) measures a median of 15 ms per request on a laptop CPU in an independent June 2026 benchmark[22]; a quantised DistilBERT-class classifier on a 4-vCPU cloud instance delivers p95 under 28 ms at sequence length 128 with int8 ONNX Runtime[23]. Those are the components inside Nolvex's 28 ms semantic budget.
- Zero-shot NER of the GLiNER class costs 160–200 ms on CPU[22], and external PII APIs cost hundreds of milliseconds[50]. That is why neither is on Nolvex's CPU hot path: zero-shot types are GPU-served, and no external service is ever called in-line.
- Rust proxies set the performance reference: Cloudflare's Pingora reduced p95 time-to-first-byte by 80 ms and CPU by about 70% against NGINX at over one trillion requests per day[27], and Rust frameworks lead the TechEmpower Round 23 benchmarks[28].
- No vendor publishes an independently verified sub-50 ms tokenisation p99; published vendor medians cluster around 30–65 ms[50]. Nolvex's design is the configuration consistent with the component evidence at 5,000 req/s, and it is proven with K6 at M2.1 rather than asserted.

Streaming responses are re-hydrated per chunk with a sliding window so the first byte is not delayed beyond the budget. Context preservation is verified by the paired-prompt benchmark in §5.2 — an approach supported by

peer-reviewed findings that typed, instance-indexed, reversible placeholders preserve LLM task quality far better than irreversible redaction[25][26].

5.8.2 Greater than 95% extraction accuracy (Track B, M2.2)

Nolvex commits to a three-part definition so that the number means what the RFP intends and can be audited:

Metric	Commitment	Measured how
End-to-end accuracy of delivered records (auto-approved plus reviewed fields)	> 95%	Field-level exact match after normalisation on the held-out test split, per class and quality band, at M2.2, M4.1 and M5.3.
Precision of auto-approved fields (those passing the 95% gate)	≥ 97%	Calibrated threshold with reported expected calibration error ≤ 0.05; auto-approval coverage reported alongside so that precision cannot be bought by routing everything to review.
Raw model accuracy before review	Reported, not gated	Per class and quality band (clean, scanned, handwritten); drives routing and threshold decisions and shows the loop improving over time.

- **Benchmark set.** At least 300 labelled documents per class, stratified by quality, split 60/20/20 for tuning, calibration and held-out testing; the test split is held by the client and never used for tuning (A-5).
- **Method.** Schema-guided prompting with retrieved exemplars; OCR cross-check on numeric and identifier fields; self-consistency on critical fields; business-rule validation; calibrated routing (§5.5).
- **What the evidence supports.** Calibrated, feature-based confidence with conformal-style thresholds is now the published state of the art for this exact problem: one 2026 study reports 99.1% accuracy at 80% auto-approval coverage after recalibration[40]; another auto-approves 49–72% of fields at a 10% error budget where native model confidence manages under 7%[39]; and the ConfBench evaluation shows that first-token log-probabilities with OCR-plus-image input give the best confidence signal while verbalised confidence is poorly calibrated[37][38]. Nolvex's evaluator is built on those findings.
- **Handwriting, stated honestly.** No public benchmark supports 95% accuracy on free-text handwritten narrative: the best model on the 2026 WildHandBench scores 71.9% against a human 77.1%[36], and on handwritten medical forms current models reach about 85–90% on discrete fields while free-text narrative remains error-prone[35]. Nolvex therefore treats handwritten *discrete* fields (dates, identifiers, codes, amounts, check-boxes) as in-gate, strengthened by validators and exemplars, and routes handwritten *narrative* fields to review by default, with their accuracy reported separately. End-to-end delivered accuracy above 95% is maintained because those fields are human-verified; the RFP's intent — no templates, handwriting handled, humans only where needed — is met without a claim the evidence cannot support.
- **Model choice.** On the OmniDocBench v1.6 leaderboard (Sep 2026) specialist open-weight document models such as PaddleOCR-VL-1.6 and MinerU2.5-Pro score above the frontier API models[33], so the open-weight fallback in A-4 is a peer, not a compromise. Candidate API models current at the time of writing are listed in §5.10; the selection is fixed at M1.1 against the benchmark.

5.8.3 Load targets — 5,000 req/s (Track A) and 1,000 docs/hr (Track B), M5.3

- **Track A.** Stateless proxy behind a network load balancer; sizing assumes 1,000–1,500 req/s per 2-vCPU pod, so 4–6 pods plus one spare meet the target with the semantic service scaled independently. Kafka audit topic with ≥ 12 partitions; ClickHouse ingestion through the Kafka engine or ClickPipes, which sustain tens of thousands of events per second per replica[29]; S3 absorbs at least 3,500 PUTs per second per prefix[30], far above the ledger writer's batch rate. K6 runs 1.5× target (7,500 req/s) for 30 minutes with p99 within budget and zero event loss.
- **Track B.** 1,000 docs/hr is roughly 17 per minute, or about 70 pages per minute at four pages per document; concurrency is bounded by VLM API limits, so the workflow applies a token-bucket limiter, page-level parallelism and batching, with the Redis queue absorbing bursts. Locust drives a 2,000-document synthetic corpus over two hours, including HITL routing at the expected rate. At current API prices (input-token cost of roughly USD 0.0002–0.005 per page across the candidate models[47]) Nolvex budgets USD 0.01–0.05 per document all-in, refined at M1.3 — so throughput is an engineering question, not a cost barrier. An open-weight VLM on client GPU capacity is the documented fallback if API quotas are insufficient (A-4).
- **Orchestration headroom.** Temporal's own published figures show sustained spikes above 150,000 actions per second on its cloud service[41]; a self-hosted cluster sized for a few hundred documents in flight has orders of magnitude of headroom.

5.8.4 Greater than 85% test coverage (M6.2)

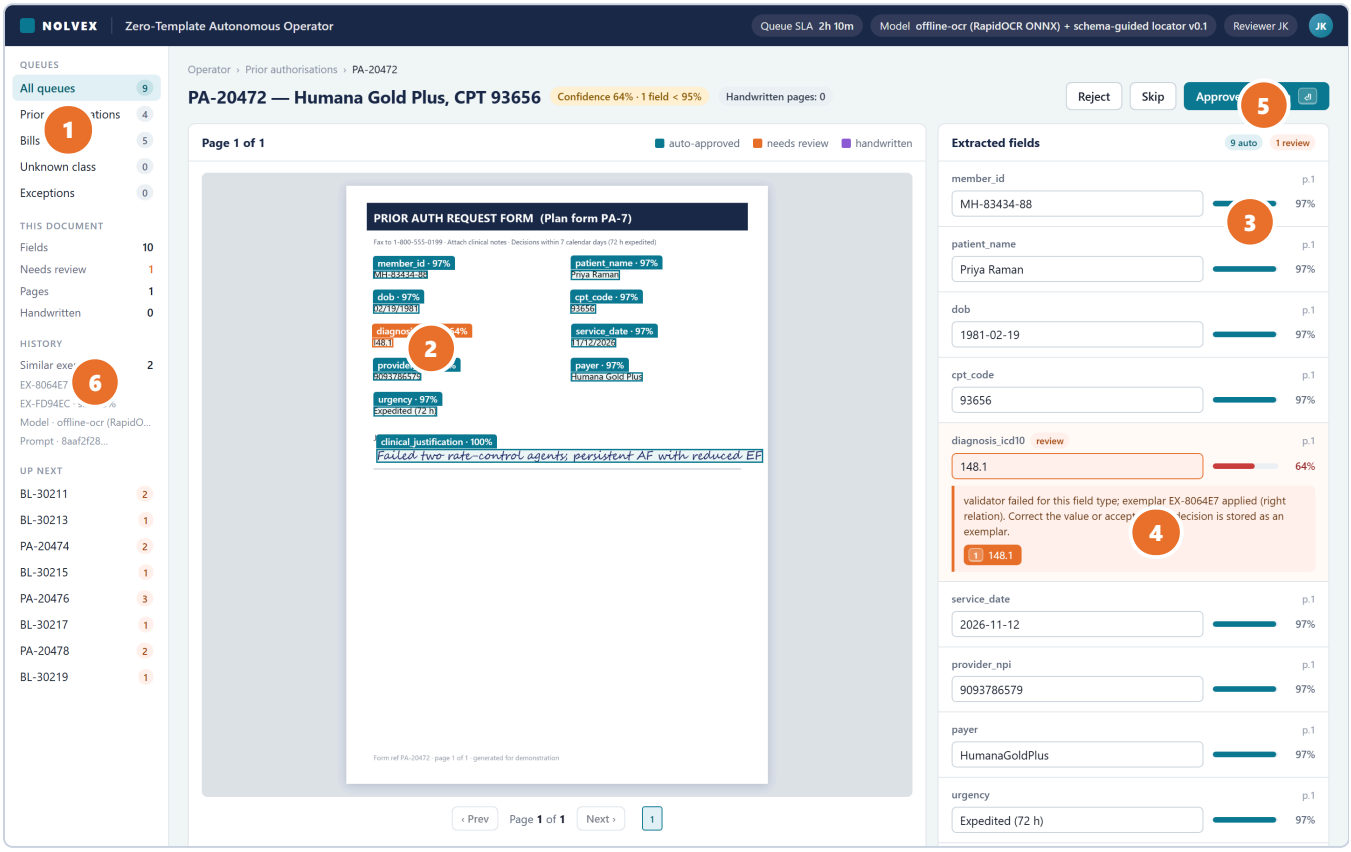
Coverage is measured per repository with cargo-llvm-cov (Rust), coverage.py (Python) and vitest coverage (TypeScript), reported on every pull request and enforced with a merge gate at 85% line coverage from Phase 2. It includes unit, integration (Testcontainers for Kafka, ClickHouse, PostgreSQL, Redis, Temporal, MinIO) and contract tests for every connector and adapter (§8).

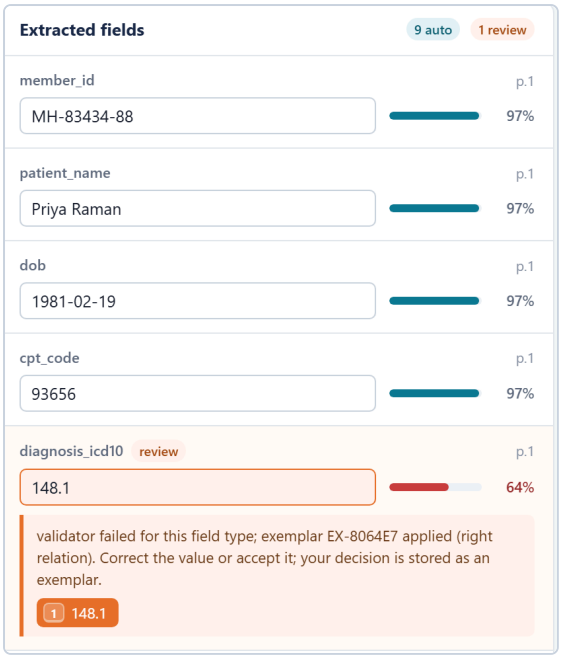
5.9 User interface — screenshots from the Nolvex demonstration build Both tracks

The RFP asks for a React/Vite HITL interface, a WORM-ledger interface with one-click export and a multi-tenant admin portal. Rather than mock-ups, the figures below are screenshots of a **working demonstration build** Nolvex assembled for this response: a React 19 / Vite front end over a Python service that implements the three-tier masking engine, session-consistent tokenization, the hash-chained ledger with an independent verifier and one-click evidence packages, zero-shot document classification, template-free schema-guided extraction over a real OCR pass, calibrated-style confidence with the 95% gate, the review workbench and the exemplar memory that changes the next extraction after a correction. Every number on these screens was produced by that build on 23 October 2026 on synthetic documents and prompts (no client data). The build is the basis of the proof-of-capability session offered in §7.3 and will be shown live.

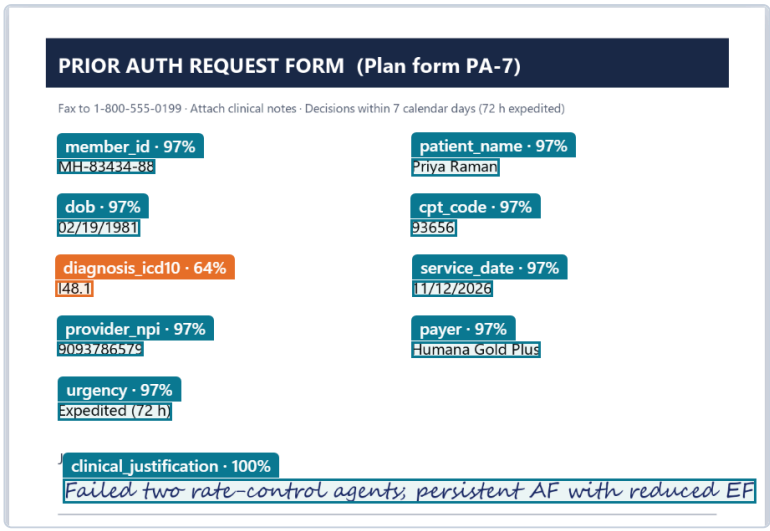
Scope of the demonstration build: it runs the masking engine in Python rather than Rust (latencies shown are its own, measured per request), keeps state in process rather than in Kafka, ClickHouse, Temporal and S3 Object Lock, and used its offline OCR provider for extraction in these captures; a vision-language-model provider (Anthropic, Google or an open-weight model) plugs into the same interface with OCR as the cross-check. The admin console's other tenants are illustrative; the Meridian Health row shows the live counters. Visual design is finalised with the Issuing Organization's brand at M1.1; every screen is built to WCAG 2.1 AA with keyboard-first operation.

Figure 7 — HITL Review Workbench (Track B, M4.1)





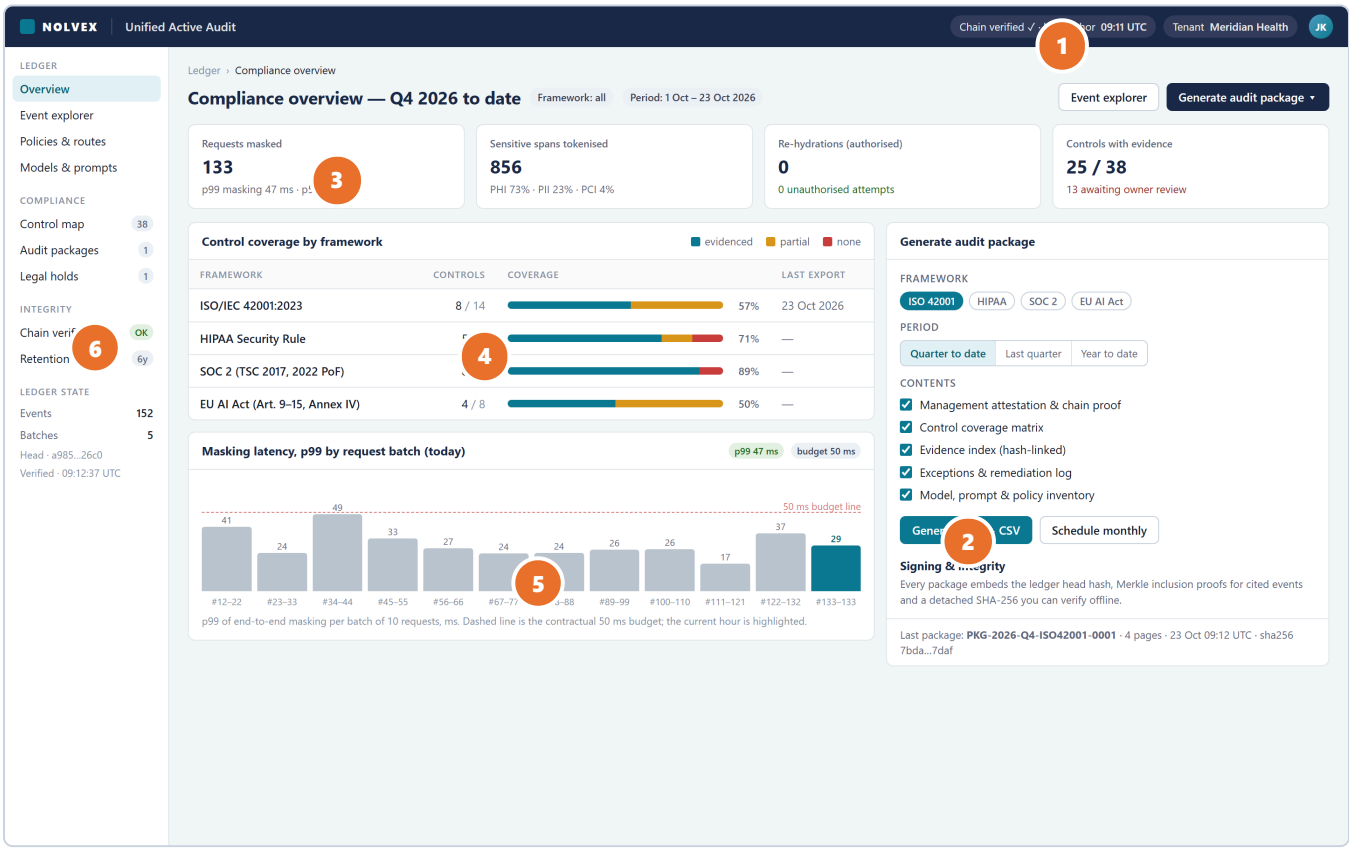
Detail: extracted fields with calibrated confidence, the one field routed to review and its explanation

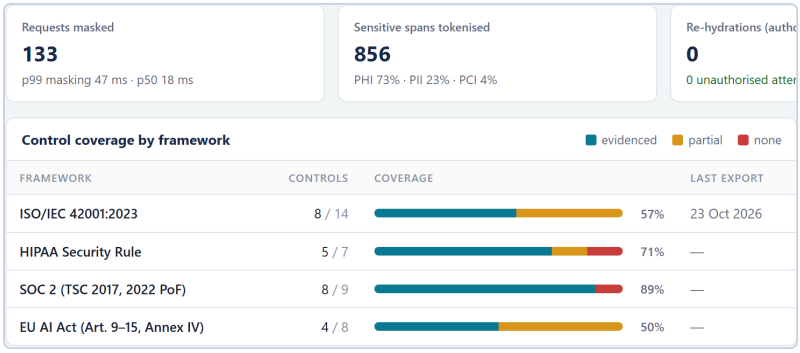


Detail: provenance overlay drawn where each field was read, including the handwritten justification line

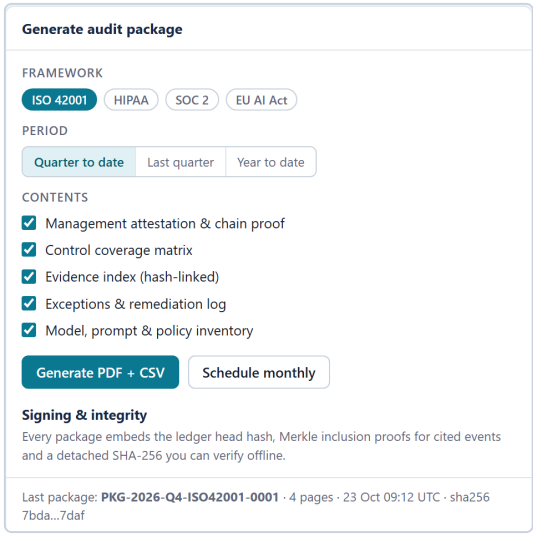
1. Skill-based queues with SLA countdowns; unknown document classes have their own queue for one-time schema assignment; "Up next" lists the remaining review work.
2. Provenance overlay: every field is drawn where it was read, teal when auto-approved, orange when under the 95% gate. Here the OCR pass read the ICD-10 code "I48.1" as "148.1"; the validator caught it and routed only that field to review.
3. Per-field confidence meters computed from observable features (OCR agreement, validators, exemplar match); nine fields auto-approved, one for review.
4. The "why" note explains the disagreement that lowered confidence and offers one-key resolutions, so a correction takes a second.
5. "Approve & retrain" writes the correction to exemplar memory and schedules the calibration refit in one action; the toast reports how many queued documents will retrieve the new exemplar.
6. History shows the two exemplars retrieved for this document from a reviewer's earlier correction on a similar form, with the model and prompt hash pinned for the ledger.

Figure 8 — Continuous Audit Ledger and One-Click Compliance Export (Track A, M4.2)





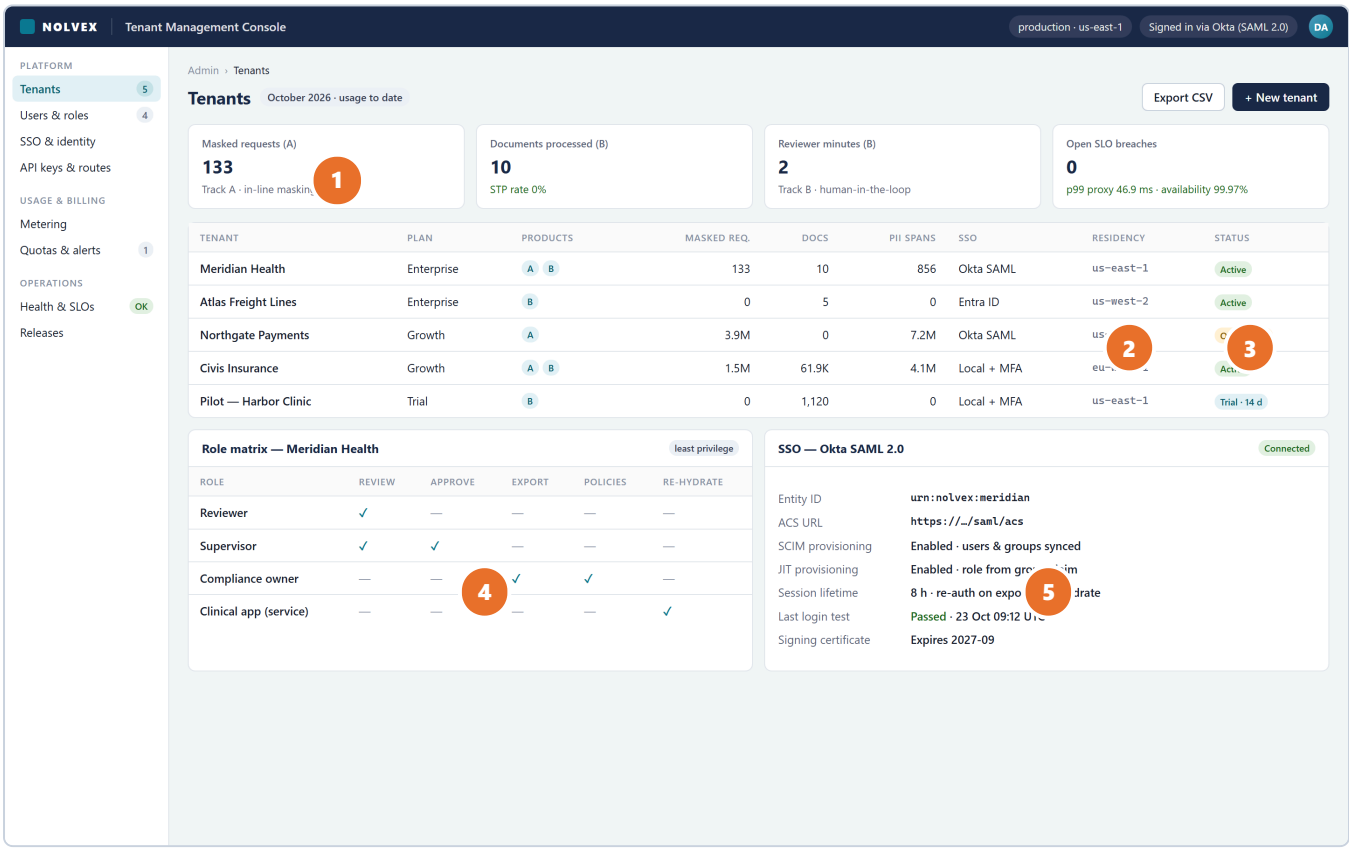
Detail: live counters and control coverage per framework, computed from the ledger and the control map



Detail: one-click audit package generation with contents, signing and the last package's hash

1. Integrity status is always visible: the result of the last chain verification and the time of the last anchor of the chain head.
2. One-click export: framework, period and contents; the generated package embeds the ledger head hash and its own SHA-256 so an auditor can verify it offline (sample package in Appendix F).
3. Live counters derived from the ledger, including the p99 and p50 masking latency the RFP specifies and the PHI/PII/PCI mix of tokenised spans.
4. Control coverage per framework computed from the control map: evidenced automatically, partial (owner attestation required) or none, with the last export date.
5. Masking p99 per batch of requests against the 50 ms budget line; the demonstration engine runs in Python and still sits under the budget for most batches.
6. Retention and legal-hold state and the ledger's current head hash and batch count, visible to the compliance owner.

Figure 9 — Multi-tenant Admin and Tenant Management Console (M4.3)



TENANT	PLAN	PRODUCTS	MASKED REQ.	DOCS	PII SPANS	SSO	RESIDENCY	STATUS
Meridian Health	Enterprise	A B	133	10	856	Okta SAML	us-east-1	Active
Atlas Freight Lines	Enterprise	B	0	5	0	Entra ID	us-west-2	Active
Northgate Payments	Growth	A	3.9M	0	7.2M	Okta SAML	us-east-1	Quota 92%
Civis Insurance	Growth	A B	1.5M	61.9K	4.1M	Local + MFA	eu-west-1	Active
Pilot — Harbor Clinic	Trial	B	0	1,120	0	Local + MFA	us-east-1	Trial · 14 d

Detail: tenants with products enabled, usage counters, identity provider, data-residency region and status

Role matrix — Meridian Health — least privilege

ROLE	REVIEW	APPROVE	EXPORT	POLICIES	RE-HYDRATE
Reviewer	✓	—	—	—	—
Supervisor	✓	✓	—	—	—
Compliance owner	—	—	✓	✓	—
Clinical app (service)	—	—	—	—	✓

Detail: role matrix with the re-hydrate permission scoped to a service identity

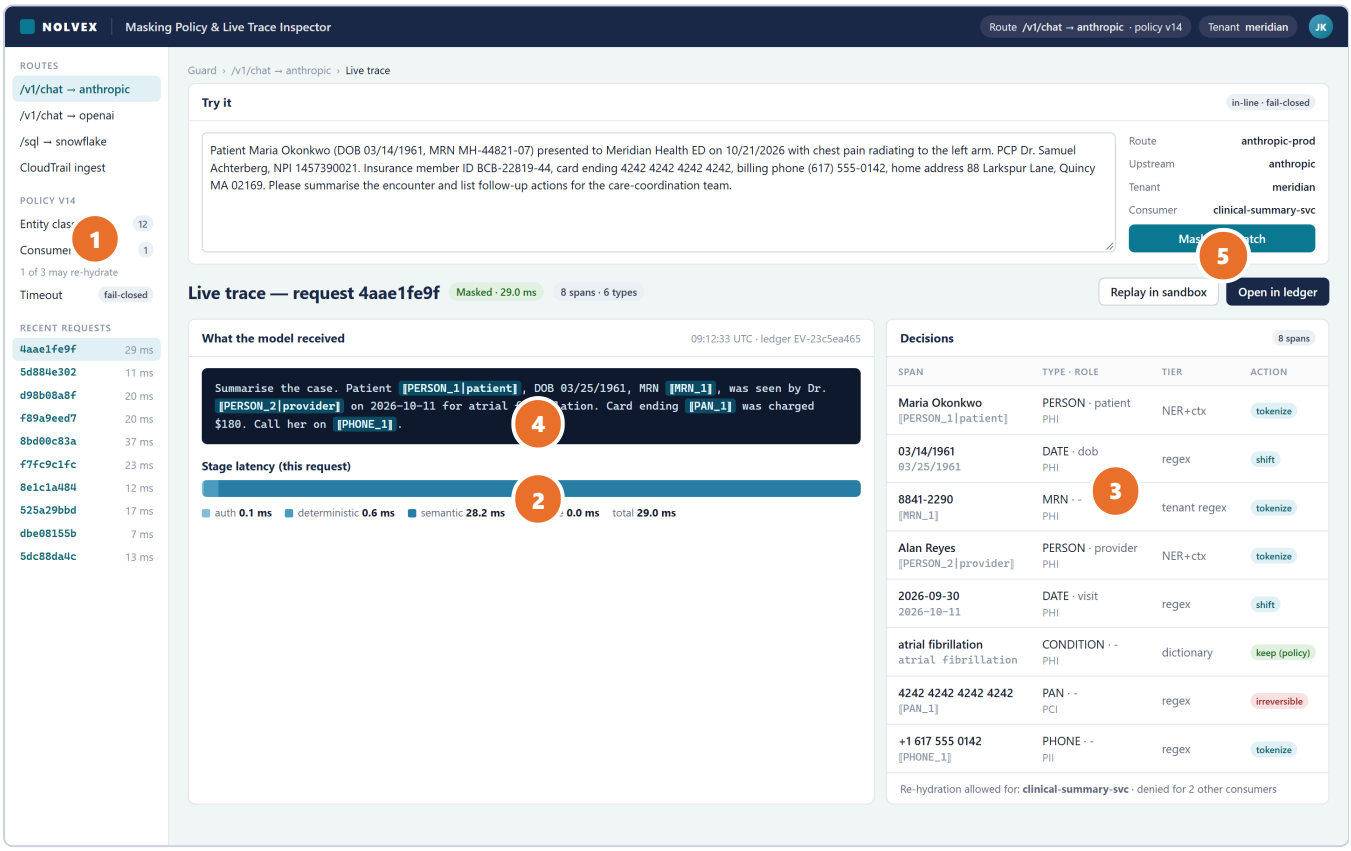
SSO — Okta SAML 2.0 — Connected

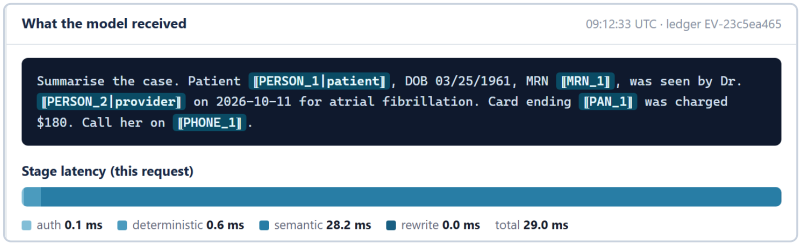
Entity ID	urn:nolvex:meridian
ACS URL	https://…/saml/acs
SCIM provisioning	Enabled · users & groups synced
JIT provisioning	Enabled · role from group claim
Session lifetime	8 h · re-auth on export & re-hydrate
Last login test	Passed · 23 Oct 09:12 UTC
Signing certificate	Expires 2027-09

Detail: SAML 2.0 / Okta configuration with SCIM, JIT and certificate expiry

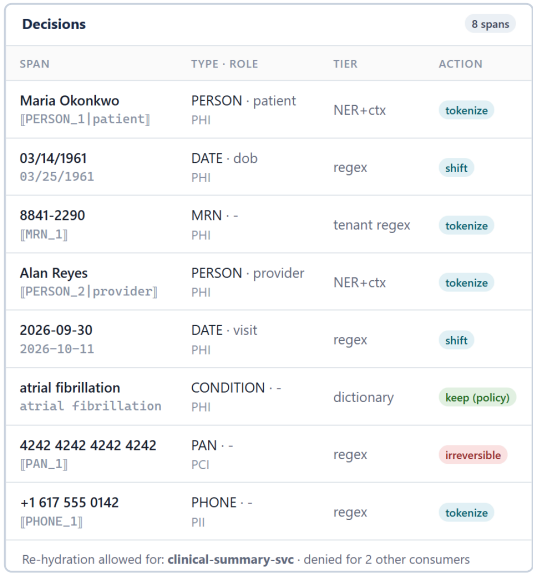
1. Usage-based metrics per product and tenant (masked requests, documents, reviewer minutes, SLO state), the metering RFP M4.3 requires, exportable for billing systems.
2. Tenant isolation is explicit: products enabled, identity provider and data-residency region per tenant; row-level security enforces it in every query.
3. Quota alerts and trial status surface the operational state the client's success team needs before customers notice.
4. Role-based access control as a visible matrix; the "re-hydrate" permission is scoped to service identities and purposes, never to a human by default.
5. SAML 2.0 / Okta integration with SCIM provisioning, group-to-role mapping and certificate-expiry monitoring, brokered by Keycloak so any SAML or OIDC provider works.

Figure 10 — Masking Policy and Live Trace Inspector (Track A, M2.1 / M4.2)





Detail: what the model received and the per-stage latency of this request (29.0 ms end to end)



Detail: every detection decision with its tier and action

1. Policy per route and tenant: twelve entity classes with their actions, the consumers authorised to re-hydrate and the fail-closed timeout behaviour.
2. Per-request latency broken down by stage against the §5.8.1 budget, measured by the engine itself, so an evaluator can inspect any request rather than a benchmark summary.
3. Every detection decision with its tier and action: regex and validators for structured identifiers, NER with contextual role for names, the card number irreversibly tokenised, and the clinical condition kept by policy because it is context, not identity.
4. What the model received: typed, role-tagged, session-consistent tokens; dates shifted by a per-session offset so intervals stay correct.
5. "Try it": any prompt can be masked and dispatched live; the resulting event opens directly in the ledger, where it is the compliance evidence.

5.10 Technology stack Both tracks

The stack follows the RFP's named technologies and otherwise favours open-source components and the client's managed cloud services, so that no licence fees are embedded in the fixed price. Versions are those current at the time of writing (checked 22 October 2026[41][44][45][46]); exact versions are pinned at M1.1 and recorded in the SBOM. Managed alternatives (Temporal Cloud, Amazon MSK, ClickHouse Cloud) are available as pass-through options (§12.5).

Layer	Component (version at time of writing)	Justification	Licence
Proxy (A)	Rust stable; Tokio, Hyper, Tower, rustls; regex / aho-corasick crates	No garbage collection; predictable scheduling for the 50 ms p99 at 5,000 req/s; linear-time multi-pattern matching. Deterministic recognisers are validated in tests against Microsoft Presidio 2.2.x as the reference implementation[21].	MIT / Apache-2.0
Semantic service (A)	Python 3.13; gRPC; ONNX Runtime 1.31; distilled token-classification NER (int8); GLiNER2-PII-class zero-shot model on a GPU replica; small sentence-embedding model	Quantised CPU inference keeps the semantic stage inside budget without mandatory GPUs; zero-shot types let tenants add entity classes without retraining; embeddings drive role assignment and context vectors.	Apache-2.0 / model-specific
Token vault (A)	PostgreSQL 17 (envelope-encrypted columns, AWS KMS); Redis 8 or Valkey cache	Durable reversible mapping per tenant with a sub-millisecond cache path; Redis also serves as the Track B execution queue (RFP §3 Phase 1).	PostgreSQL / AGPL-3.0 or BSD-3
Event backbone (A, B)	Apache Kafka 4.x (KRaft), self-hosted on Kubernetes; Amazon MSK optional	Durable ordered log; topologies defined at M1.2; no ZooKeeper to operate.	Apache-2.0
Event store / WORM (A)	ClickHouse 25.x (Kafka engine or ClickPipes); Amazon S3 Object Lock in compliance mode; SHA-256 hash chain with RFC 3161 timestamps	Named in the RFP; columnar queries at low cost; storage-enforced immutability that no principal can shorten[30][32]. Hash-chain-plus-Object-Lock is the pattern recommended since AWS retired QLDB in July 2025[31].	Apache-2.0 / client AWS
Compliance generator (A)	Python; DuckDB; Apache Arrow; WeasyPrint (PDF); control map in PostgreSQL	Low-cost columnar export; PDF generation without commercial libraries; editable, versioned control mapping.	MIT / BSD
VLM core (B)	Client-approved API model; open-weight fallback served by vLLM (PaddleOCR-VL-1.6, MinerU2.5 or Qwen3-VL class); PaddleOCR for cross-check; OpenCV	Template-free extraction; model choice remains with the client; OCR cross-check improves numeric accuracy; open-weight leaders currently match or exceed API models on document benchmarks[33].	Apache-2.0 / API terms
Active-learning memory (B)	PostgreSQL 17 + pgvector 0.8 (HNSW)	Stores corrections as retrievable exemplars and routing rules without a separate vector database.	PostgreSQL
Orchestration (B)	Temporal 1.32 (self-hosted on Kubernetes with PostgreSQL persistence; Temporal Cloud optional); Worker Deployments for versioning; Redis queue	Named in the RFP; durable execution for human-gated lifecycles; Temporal Cloud holds SOC 2 Type 2 and HIPAA attestations should the client prefer managed operation[41].	MIT (server)
HITL, ledger and admin UI	React 19.3; Vite 8 (Rolldown); TypeScript; TanStack Query; pdf.js 6.x; axe-core	Named in the RFP; fast builds; in-browser document rendering; automated accessibility checks.	MIT / Apache-2.0

Layer	Component (version at time of writing)	Justification	Licence
Write-back (B)	Python adapters: fhir.resources / fhirclient (FHIR R4, SMART Backend Services); NetSuite SuiteTalk REST; Paramiko (SFTP); Zeep (SOAP); SQLAlchemy (DB sync)	Maintained client libraries for each target; one adapter contract (§5.7).	Apache-2.0 / MIT
GUI fallback (B)	Playwright 1.64 (aria-ref grounding); pywinauto / UI Automation for desktop; VLM screen understanding (client-approved computer-use-capable model)	Deterministic browser automation with screenshot verification; desktop only where unavoidable; vision grounding only when selectors fail[42][44].	Apache-2.0 / BSD
Identity and tenancy	Keycloak 26.8 (SAML 2.0 and OIDC broker; Okta as upstream IdP; SCIM); RBAC in PostgreSQL with row-level security; OPA policy	SAML 2.0 / Okta SSO and multi-tenant RBAC required at M4.3 without commercial licences.	Apache-2.0
API contracts and gateway	OpenAPI 3.0; Protocol Buffers / gRPC; Envoy Gateway 1.9+ (or AWS API Gateway)	Formal contracts at M1.1; production API gateway at M6.1. Envoy Gateway replaces Kong, whose open-source line was frozen at 3.9 with no further OSS images[45].	Apache-2.0 / client AWS
Platform	Kubernetes (EKS or GKE); Helm; Terraform (OpenTofu-compatible modules); GitHub Actions; Argo CD	IaC and GitOps; HA deployment at M6.1; modules written to run on OpenTofu so the client is not bound to Terraform's licence terms.	Apache-2.0 / MPL-2.0
Security	AWS KMS; AWS Secrets Manager or HashiCorp Vault; cert-manager; Trivy; Semgrep; gitleaks; cosign; CycloneDX	Secrets, keys, scanning and signed artefacts (§6).	Apache-2.0 / MPL
Observability and testing	OpenTelemetry; Prometheus; Grafana; Loki; cargo test; pytest; vitest; Playwright; Grafana k6 2.3; Locust 2.47; Testcontainers	Evidence for latency, throughput and coverage gates; K6 and Locust named in the RFP.	Apache-2.0 / AGPL (Grafana)

Candidate models (selection fixed at M1.1 against the client's benchmark and provider approvals)

Use	Candidates current at the time of writing[33][42][47]	Selection criteria
Track A — statistical NER and embeddings	Distilled DeBERTa/DistilBERT-class token classifiers fine-tuned on PII/PHI corpora, int8; GLiNER2-PII-class zero-shot model for tenant-defined types; a small sentence-embedding model for role and context vectors.	p99 latency inside the 28 ms budget on CPU; F1 on the client's PII corpus; licence compatible with assignment to the client.
Track A — connected LLMs	OpenAI and Anthropic APIs as named in RFP §3 (current generations: GPT-5.5 / 5.6 and Claude Opus 5.5 / Sonnet 5.5 / Haiku 5.5), including streaming and tool-call payloads.	Whatever the client's workloads use; the proxy is provider-agnostic.
Track B — vision-language extraction (API)	Claude Sonnet 5.5 / Haiku 5.5; Gemini 3.8 Flash / 3.1 Pro; GPT-5.5; Mistral OCR 3 for pre-extraction where cost matters.	Accuracy on the held-out set per class; calibration quality; cost per page; data-residency and BAA availability (A-6, R9).
Track B — open-weight fallback (client GPU)	PaddleOCR-VL-1.6; MinerU2.5-Pro; Qwen3-VL; DeepSeek-OCR 2 — the current OmniDocBench v1.6 leaders.	Same benchmark; serving cost on the client's GPU capacity (A-4); residency.
Track B — GUI agent grounding	A computer-use-capable model from the client's approved providers (e.g. Claude Sonnet 5.5 with the computer-use toolset).	Used only when deterministic selectors fail; every action screenshot-verified.

Model names and versions are recorded in the System Architecture Document at M1.1 and pinned per decision in the ledger thereafter; provider deprecations are handled through the routing layer (R14).

Confidential —prepared for the Issuing Organization. ©2026 Nolvex.

6 Security and Compliance Approach

Both systems are built so that the Issuing Organization can evidence controls under SOC 2 (Type II readiness), HIPAA and ISO/IEC 42001, and so that Track A's compliance generator can map events to those frameworks and to the EU AI Act. Nolvex does not itself hold these certifications and claims none; the deliverable is a system whose controls, documentation and evidence support the client's own audits. The regulatory picture below is current as of 22 October 2026 and is the baseline for the control map delivered at M1.1 and verified at M5.1 (sources in Appendix H).

6.1 The regulatory landscape this platform must evidence (October 2026)

Framework	Status at the time of writing	What it means for the delivered platforms
EU AI Act (Reg. (EU) 2024/1689, as amended)	The "Digital Omnibus on AI" was adopted as Regulation (EU) 2026/1744 and entered into force on 27 July 2026. Annex III high-risk obligations (Articles 9–15, 17) now apply from **2 December 2027** (previously 2 August 2026); Annex I product-embedded systems from 2 August 2028; synthetic-content marking under Article 50(2) from 2 December 2026. GPAI obligations have applied since August 2025 and the Commission's fining powers since 2 August 2026. The first harmonised standard, EN 18286:2026 (quality management systems for Article 17), was cited in the Official Journal on 14 October 2026; logging, oversight and robustness standards are still in drafting. Penalties reach EUR 35 million or 7% of worldwide turnover for prohibited practices and EUR 15 million or 3% for most operator obligations[51][52][54][55].	Track B deployments that evaluate eligibility for healthcare services or support insurance decisions may fall within Annex III depending on use; the control map therefore covers Articles 9 (risk management), 10 (data governance), 11 and Annex IV (technical documentation), 12 (record-keeping), 13 (transparency), 14 (human oversight), 15 (accuracy, robustness, cybersecurity) and 17 (QMS), so that the client's customers can evidence them from the ledger ahead of the December 2027 date. The Annex IV documentation pack is an optional add-on (§12.8). The control map is versioned data, so the amended timeline and future harmonised standards are absorbed without code change (R13).
HIPAA Security and Privacy Rules	The current Security Rule remains law. HHS's January 2025 Notice of Proposed Rulemaking to strengthen it — mandatory encryption and MFA, an ePHI asset inventory and network map, restoration of critical systems within 72 hours, annual compliance audits, vulnerability scans every six months and annual penetration tests — is **not final**; HHS's spring 2026 agenda moved the target to July 2027[56][57]. The 2024 reproductive-health privacy rule was vacated nationally in June 2025[58].	Nolvex builds to the proposed rule now, so that nothing needs re-engineering when it is finalised: encryption in transit and at rest everywhere, MFA through SSO, an automatically maintained inventory of ePHI data flows (the connector and adapter registry), documented 72-hour restoration demonstrated at M5.1, and six-monthly scanning and annual penetration testing written into the SLA (§12.6). Business Associate Agreements with providers remain the client's responsibility (A-6).
ISO/IEC 42001:2023 (AI management systems)	Published December 2023; supplemented by ISO/IEC 42005:2025 (AI system impact assessment, May 2025) and ISO/IEC 42006:2025 (requirements for certification bodies, July 2025). Accredited certification is now available (ANAB-accredited certifiers since September 2024; BSI became the first UKAS-accredited body in November 2025); Anthropic, AWS and Microsoft hold certificates[59][60][61].	The platforms produce the artefacts an ISO 42001 audit asks for: AI system inventory and model cards (A.4, A.6.2.7), impact assessments per 42005 (6.1.4, A.5), operation and monitoring (A.6.2.6), **recording of event logs (A.6.2.8)**, responsible-use and intended-use statements (A.9), and third-party model governance (A.10). Appendix C maps each to a system feature and evidence.
SOC 2 (AICPA Trust Services Criteria)	The criteria remain the 2017 TSC with the 2022 revised points of focus; a Type II report covers operating effectiveness over a period, typically 6–12 months. AICPA's 2026 activity focuses on audit quality rather than new criteria[62].	Because evidence is derived continuously from the ledger, the observation window can start at go-live; M5.1 delivers the control-by-control evidence index for Security, Availability, Processing Integrity and Confidentiality criteria.
NIST AI RMF 1.0 and AI 600-1; NIST CSF 2.0	Voluntary frameworks widely referenced by US buyers; NIST states the AI RMF is being revised in 2026[63].	The control map includes a crosswalk to the AI RMF functions (Govern, Map, Measure, Manage) so that US customers asking for NIST alignment receive the same evidence packages.

Framework	Status at the time of writing	What it means for the delivered platforms
US state AI laws	Colorado repealed and re-enacted its AI Act as SB 26-189 (signed 14 May 2026, effective 1 January 2027) covering automated decision-making technology in consequential decisions: notice, adverse-decision disclosure, human review and record-keeping[64]. Texas TRAIGA has applied since 1 January 2026[65]; California's CCPA automated decision-making regulations took effect 1 January 2026 with compliance due 1 January 2027[66]; New York's RAISE Act takes effect 1 January 2027[67].	Track B's prior-authorisation and similar workflows are consequential decisions under these laws; the HITL workbench, reviewer records and ledger supply the human-review and record-keeping evidence, and the decision explanation stored per document supports adverse-decision disclosure.
CMS-0057-F (Interoperability and Prior Authorization)	Decision time frames (72 hours expedited, 7 calendar days standard) and public prior-authorisation metrics have applied since 1 January 2026; the FHIR Prior Authorization, Provider Access and Payer-to-Payer APIs are due **1 January 2027**. CMS recommends, but does not require, the HL7 Da Vinci CRD, DTR and PAS implementation guides. Around 53 health plans separately pledged a FHIR electronic prior-authorisation framework by 2027[68][75].	Track B's prior-authorisation class is designed around these time frames (SLA timers in Temporal) and the Da Vinci PAS profile for payer submission where supported, which is the write-back path that becomes standard in 2027.

6.2 Framework alignment

Framework	Design measures in the delivered systems
SOC 2 Type II	Immutable audit ledger (CC7.2, CC7.3); RBAC with SSO and least privilege (CC6.1–CC6.3); encryption in transit and at rest (CC6.6, CC6.7); change management through GitOps with reviewed, signed commits and SBOMs (CC8.1); monitoring and alerting (CC7.1); backup and restoration (A1.2); accuracy controls and reviewer records for Processing Integrity (PI1). Readiness verification at M5.1 produces a control-by-control evidence index suitable for a Type II observation period.
HIPAA	PHI detection and tokenisation at the proxy (Track A); PHI in Track B confined to KMS-encrypted stores; every PHI touch logged to the ledger (§164.312(b)); integrity through hash chaining and Object Lock (§164.312(c)(1)); transmission security with TLS 1.3 and tokenisation before external model calls (§164.312(e)(1)); access control via SSO, RBAC and row-level security (§164.312(a)(1)); information-system activity review from the ledger (§164.308(a)(1)(ii)(D)); contingency planning with demonstrated restoration (§164.308(a)(7)); six-year retention of documentation (§164.316(b)(2)); minimum-necessary data in exports.
ISO/IEC 42001	AI system inventory and model cards for NER, embedding and VLM models; intended use, limitations and metrics; impact-assessment template aligned to ISO/IEC 42005; human oversight through HITL thresholds and override; model version and prompt hash logged per decision (A.6.2.8); accuracy-drift monitoring (A.6.2.6); third-party model governance (A.10).
EU AI Act	Control-map entries for risk management (Art. 9), data governance (Art. 10), technical documentation (Art. 11, Annex IV), automatic logging (Art. 12), transparency (Art. 13), human oversight (Art. 14), accuracy and robustness (Art. 15) and quality management (Art. 17), so that Track A exports can evidence them; the full Annex IV documentation pack is an optional add-on (§12.8).
US state ADMT laws	Per-document decision record with explanation; human-review evidence; adverse-decision disclosure data; retention aligned to the longest applicable period.

6.3 Data protection, residency and threat model

- **Data classification.** Four classes (public, internal, confidential, regulated: PII/PHI/PCI) with handling rules enforced in code: regulated data never appears in logs, traces, error messages or the ledger (token identifiers and counts only), and never leaves the client's region un-tokenised.
- **Residency.** All stores (Kafka, ClickHouse, S3, PostgreSQL, Redis, Temporal) are deployed in client-selected regions. No data leaves those regions except calls to client-approved model APIs, which are documented with endpoint regions and data categories sent; semantic tokenisation is applied before any payload reaches an external model. Residency constraints are captured at M1.1 and verified at M5.1.

- **Threat model.** Delivered at M1.1 using STRIDE per trust boundary (client workload → proxy, proxy → semantic service, proxy → connector, workflow → adapter, GUI agent → legacy application, user → workbench and portal), with abuse cases specific to this product: prompt-injection attempts to exfiltrate tokens, re-hydration by an unauthorised consumer, poisoning of the active-learning memory through malicious corrections, and GUI-agent manipulation by a changed screen. Each has a named control and a test.
- **Tenant isolation.** Row-level security on every table; per-tenant KMS keys for the token vault; per-tenant Kafka partition keys and S3 prefixes; isolation tests in CI.
- **PCI scope reduction.** Primary account numbers are tokenised irreversibly at the proxy and never stored, keeping downstream systems out of PCI DSS scope.

6.4 Secrets management

- All credentials (connector keys, model API keys, FHIR client certificates, NetSuite OAuth client credentials, SFTP keys, SAML signing keys) are held in AWS Secrets Manager or HashiCorp Vault and injected at runtime; none are stored in repositories, images or workflow payloads.
- Encryption keys in AWS KMS with rotation and separate keys per environment and tenant; S3 ledger objects use SSE-KMS; token-vault columns are envelope-encrypted.
- Workload identity (IRSA / Workload Identity) instead of long-lived cloud keys; secret access is itself written to the ledger.
- Pre-commit and CI secret scanning (gitleaks); signed commits; dependency pinning.

6.5 Penetration testing approach (M5.2)

- Continuous automated scanning throughout the build: Trivy (images, dependencies), Semgrep, OWASP ZAP baseline against the workbench, admin portal and APIs; findings triaged weekly.
- An accredited third-party penetration test (CREST or equivalent) in Phase 5, week 17, commissioned by the client or by Nolvex as a pass-through (§12.5). Scope: external and internal network, web applications, APIs (proxy, export, workflow, admin), SAML/SSO flow, cloud configuration review, and product-specific abuse cases from the threat model (token exfiltration via prompt injection, unauthorised re-hydration, memory poisoning).
- Nolvex remediates all High and Critical findings and obtains a signed re-test confirmation from the auditor before M5.2 acceptance; Medium and Low findings are remediated or risk-accepted by the client in writing.

6.6 Additional controls and Nolvex's engagement posture

- **Application security:** input validation at every boundary; parameterised queries; CSP and CSRF protection; rate limiting; output encoding in the workbench; dependency and container scanning on every build.
- **Supply chain:** pinned dependencies; CycloneDX SBOM per release; cosign-signed images; provenance attestations from CI.
- **Backup and recovery:** documented RPO/RTO per store; ledger recovery from S3 and PostgreSQL point-in-time restore demonstrated at M5.1 within the 72-hour window the proposed HIPAA rule would require.
- **Incident response:** runbooks for data-exposure, availability and integrity incidents; breach-notification timelines aligned to HIPAA and the client's contracts; post-incident reviews feed the risk register.
- **Nolvex's own posture for this engagement:** Nolvex personnel sign confidentiality undertakings; all work is performed in client-controlled environments with MFA and least-privilege access granted by the client (A-7); no client data is stored on Nolvex systems; access is revoked at handover and confirmed in writing.

7 Delivery Plan

The programme follows the six phases, 24 weeks and 18 milestones of RFP §3 exactly. Each phase closes with a phase-gate review at which the Issuing Organization accepts the phase's milestones against the written criteria in Appendix A; acceptance triggers the corresponding invoice (§12.3). Track A and Track B workstreams run in parallel inside each phase; Phase 1, M4.3 and Phases 5–6 are shared, which is the source of the combined-package efficiency (§12.2).

7.1 Phase-by-phase plan

Phase (RFP §3)	Weeks	Milestone	Deliverable and acceptance summary (full criteria in Appendix A)	Track	Phase-gate demo
1 Architecture, Security Blueprints & Setup	1–4	M1.1	System Architecture Document and OpenAPI 3.0 / gRPC contracts approved; benchmark set and accuracy definition; compliance control map and threat model; model and provider selections; document classes and connector scope frozen.	Both	Walk-through of SAD; Terraform apply from a clean account; sample PR through the full CI gate.
		M1.2	PostgreSQL schemas, ClickHouse event store, Redis queue structures, Kafka topologies and Temporal state-machine blueprints finalised and versioned.	Both	
		M1.3	CI/CD pipelines and modular Terraform deployed to staging Kubernetes (EKS/GKE) with coverage and security gates active.	Both	
2 Differentiator Core Engines	5–8	M2.1	Sub-50 ms semantic tokenization and PII masking proxy operational under K6 stress; context-preservation benchmark report; fail-closed behaviour verified.	A	Live masking on client prompts with latency histogram; extraction of unseen client documents; workflow surviving a worker restart.
		M2.2	Layout-agnostic VLM extraction engine achieving > 95% on the held-out benchmark incl. handwritten samples; calibration report.	B	
		M2.3	Temporal.io state machine managing asynchronous orchestration, retries, timers and exception paths.	B	
3 Enterprise Integrations & Autonomous Connectors	9–12	M3.1	Live connectors operational for AWS CloudTrail, Snowflake, OpenAI and Anthropic APIs with masking applied and audit events flowing.	A	End-to-end: document in, record verified in the client sandbox (FHIR, NetSuite, SFTP); GUI agent completing the agreed legacy scenario.
		M3.2	Live write-back adapters for Epic / Oracle Health (FHIR), NetSuite and SFTP; REST, SOAP and database-sync adapters passing contract tests; compensation path tested.	B	
		M3.3	Computer-vision virtual GUI agent functional against the agreed legacy application with screenshot verification, allow-lists and dry-run.	B	
4 HITL Interface, Compliance Ledger & Admin UI	13–16	M4.1	HITL workbench deployed with side-by-side validation, annotation and the active-learning feedback loop; "one correction changes the next extraction" demonstrated.	B	Reviewer session on live queue; audit package generated and chain-verified in front of the client; SAML login through the client's Okta tenant.
		M4.2	Continuous WORM audit ledger interface and one-click compliance generator (PDF/CSV mapped to ISO 42001, HIPAA, SOC 2, EU AI Act); tamper detection test passed.	A	
		M4.3	Multi-tenant admin and tenant-management portal with RBAC, SAML 2.0 / Okta SSO and usage-based billing metrics.	Both	

Phase (RFP §3)	Weeks	Milestone	Deliverable and acceptance summary (full criteria in Appendix A)	Track	Phase-gate demo
5 Hardening, Security Auditing & Beta Testing	17–20	M5.1	SOC 2 Type II and HIPAA security-controls audit readiness verified; control-by-control evidence index; backup, restore and ledger recovery demonstrated.	Both	Penetration-test close-out with the auditor; K6 and Locust results reviewed; UAT sign-off meeting.
		M5.2	Accredited third-party penetration test completed; all High and Critical findings remediated and confirmed by signed re-test.	Both	
		M5.3	UAT stress testing passed (5,000 req/s Track A, 7,500 req/s soak; 1,000 docs/hr Track B, 2,000-document run); K6/Locust scripts and reports; UAT sign-off.	Both	
6 Production Rollout, Handover & Documentation	21–24	M6.1	Systems deployed on the client's production cloud: HA Kubernetes behind production API gateways; smoke tests, monitoring and alerting live.	Both	Go-live report; repository and documentation hand-over; training sessions; SLA contract executed; warranty start confirmed.
		M6.2	Source code, IaC and build repositories delivered with coverage > 85%; runbooks, API developer documentation and SDK references, end-user and administrator manuals.	Both	
		M6.3	Operational training completed; SLA maintenance contract (Tier 1–3 response times) executed; hypercare and warranty begin.	Both	

Dependencies on client inputs are listed in §11 with the week each is needed; a delay in a listed input shifts the dependent milestone by the same duration without changing the fixed price (A-2).

7.2 24-week Gantt chart

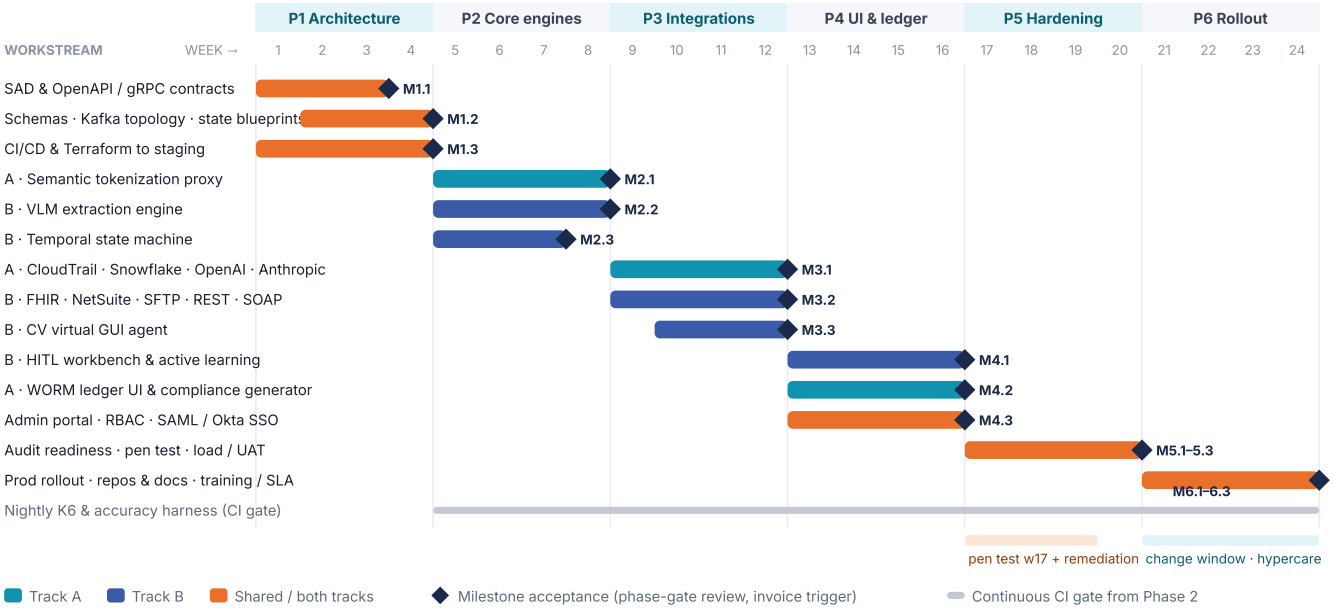


Figure 11 — 24-week delivery schedule with milestone acceptance points. Phase boundaries per RFP §4: P1 w1–4 · P2 w5–8 · P3 w9–12 · P4 w13–16 · P5 w17–20 · P6 w21–24. The penetration test starts in week 17 to leave three weeks for remediation and re-test before M5.2; the nightly latency and accuracy harness runs from week 5 so regressions are caught the night they happen.

7.3 Proof-of-capability demonstration before contract

RFP §5 weights "ability to demonstrate" the differentiators at 30%. Nolvex has already built a working demonstration of both tracks for this response (screenshots in §5.9) and offers, at no cost and without obligation, a live session on it within ten business days of being shortlisted:

Demonstration	What the evaluator sees	What Nolvex needs from you
In-line semantic masking	Your sample prompts sent through a prototype proxy to a client-approved model; the masked prompt, the model's response and the re-hydrated response side by side; per-request stage latencies on a live histogram under synthetic load.	20–50 sample prompts (synthetic or de-identified) and the model provider you prefer.
Zero-template extraction	Unseen documents of two classes, including handwritten pages, extracted against a schema agreed the day before; per-field confidence and provenance shown in the workbench concept.	20–40 sample documents per class with no layout information.
Closed-loop correction	A reviewer corrects a field on one document; the next similar document is extracted correctly, with the retrieved exemplar shown.	Nothing further.

The demonstration uses prototype components, not the production build; its purpose is to let the evaluation rest on observed behaviour. Sample data is processed only in an environment the Issuing Organization approves and is deleted after the session.

7.4 Governance and communication

Forum	Cadence	Purpose and participants
Daily overlap window	Mon–Fri, 3:00–6:00 pm EAT / 8:00–11:00 am EST	Decisions, blockers, pairing with client engineers; guaranteed availability of the Project Lead; extended for UAT (weeks 17–20) and rollout (weeks 21–24).
Written status report	Weekly (Friday)	Progress against the Gantt, burn against milestones, risks and decisions needed, upcoming client dependencies; one page, same format every week.
Sprint demo	Fortnightly	Working software demonstrated on the staging environment; backlog re-prioritised with the product owner.
Steering meeting	Fortnightly	Client sponsor and Nolvex Director: scope, schedule, commercial matters, escalations.
Phase-gate review	End of each phase	Milestone acceptance against Appendix A, risk register review, authorisation to proceed and invoice.
Decision log and change control	Continuous	Every decision recorded with owner and date; 24-hour default on open decisions within the overlap window; scope changes by written change request (§12.10).

Tooling: a shared Slack or Teams channel, a shared backlog (Jira or GitHub Projects, client's choice), the repositories themselves (client has read access from week 1) and the staging environment for continuous demonstration.

8 Quality Assurance, CI/CD and Testing

8.1 Engineering process

- **Trunk-based development** with short-lived branches; every change through a pull request with at least one reviewer; conventional, signed commits; architecture decision records (ADRs) for every significant choice.
- **Definition of Done** per story: code, tests, documentation, security scan clean, coverage gate met, deployed to the test environment, demonstrated.
- **Fortnightly sprints** aligned to phase milestones; sprint demos on staging; shared backlog and decision log.
- **Model and prompt changes are code**: prompts, schemas, exemplars and calibration models are versioned, reviewed and gated by the evaluation harness exactly like software.

8.2 CI/CD pipeline (GitHub Actions, Argo CD) — M1.3

Stage	Checks	Gate
Lint and format	clippy, rustfmt, ruff, mypy, eslint, prettier	Zero warnings on changed code
Contract validation	OpenAPI 3.0 lint (Spectral); protobuf breaking-change check (buf)	No breaking change without version bump
Unit tests	cargo test, pytest, vitest	All pass
Coverage	cargo-llvm-cov, coverage.py, vitest coverage; merged report (SonarQube Community)	≥ 85% line coverage per repository; no decrease on PR
Integration tests	Testcontainers: Kafka, ClickHouse, PostgreSQL, Redis, Temporal, MinIO; connector and adapter contract tests against recorded fixtures	All pass
Evaluation harness	Masking precision/recall on the PII corpus; extraction accuracy and calibration on the benchmark tuning split; context-preservation sample	No regression beyond tolerance; full nightly run
Security	Trivy (images, dependencies), gitleaks, Semgrep, OWASP ZAP baseline (HITL app, admin portal, APIs)	No Critical/High
Accessibility	axe-core in Playwright for every UI route	No WCAG 2.1 AA violations
Performance (nightly)	K6 latency and throughput suite (Track A); Locust document-throughput suite and accuracy harness (Track B) against staging	p99 < 50 ms; accuracy > 95%; regression alert
Build and publish	Multi-arch images, CycloneDX SBOM, cosign signature, Helm chart versioning	Signed artefacts only
Deploy	Argo CD: dev automatically; staging on tag; production on client approval; canary with automatic rollback on SLO breach	Client approval for production

8.3 Test levels

Level	Scope	Owner
Unit	Detection rules, tokenization, validators, confidence scoring, adapter mapping, RBAC policies, UI components.	Developing engineer
Integration	Proxy ↔ semantic service ↔ Kafka ↔ ClickHouse ↔ S3; workflow ↔ VLM ↔ evaluator ↔ HITL ↔ adapters; SSO ↔ portal.	Backend / ML engineers

Level	Scope	Owner
Contract	Each connector and adapter against sandbox or recorded responses; OpenAPI/gRPC conformance.	Backend engineer
End-to-end	Playwright flows through the workbench and admin portal; document lifecycle intake → write-back → ledger entry; SAML login.	DevOps/QA engineer
Performance	K6 (5,000 and 7,500 req/s soak); Locust 2,000-document corpus; latency histograms per connector.	DevOps/QA engineer
Accuracy and calibration	Evaluation harness on the stratified benchmark with held-out split; per-field, per-class and calibration reports.	ML/VLM engineer
Security	Automated scanning continuously; accredited third-party penetration test in Phase 5.	DevOps/QA; third party
Acceptance (UAT)	Client-executed UAT scripts per enterprise user story, prepared by Nolvex (Appendix A, M5.3).	Client, supported by Nolvex

8.4 Defect management and warranty

Defects are logged with severity S1 (blocker) to S4 (cosmetic). Milestone acceptance requires zero open S1/S2 defects in scope; S3/S4 may be deferred by written agreement. Defects raised during UAT and the 90-day warranty are fixed at no charge where within RFP scope. Accuracy regressions detected by the nightly harness are treated as S2 defects.

Confidential —prepared for the Issuing Organization. ©2026 Nolvex.

9 Risk Register and Heat Map

Likelihood (L) and impact (I) are scored 1–5; score = L × I. The register is reviewed at every phase gate and in the weekly status report; each risk has a named owner and a trigger that converts it into an issue.

ID	Risk	L	I	Score	Mitigation	Owner
R1	VLM accuracy below 95% on certain classes (handwriting, poor scans).	3	5	15	Stratified benchmark at M1.1; OCR cross-check; self-consistency; calibrated routing bounds auto-approved error; active learning from corrections; open-weight fallback model; per-class thresholds.	ML/VLM Eng.
R2	p99 masking latency exceeds 50 ms under peak load.	3	4	12	Per-stage latency budget; deterministic pass resolves most spans; quantised models with hard deadline; nightly K6 from Phase 2; horizontal scaling; fail-closed policy preserves safety when slow.	Backend Eng.
R3	Delayed sandbox access to Epic, Oracle Health, NetSuite, Snowflake or AWS.	4	4	16	Access requested at kick-off (§11); contract tests against recorded fixtures and public FHIR sandboxes until access arrives; schedule shift per A-2.	Client / Lead
R4	VLM/LLM API quotas or costs constrain 1,000 docs/hr.	3	3	9	Rate limiter, batching, page-level parallelism; quota increase requested early; open-weight VLM on client GPU as fallback (A-4); cost dashboard per tenant.	ML/VLM Eng.
R5	Penetration test surfaces Critical findings late in Phase 5.	2	4	8	Continuous scanning from Phase 1; threat model at M1.1; pen test starts week 17 with three weeks for remediation and re-test.	DevOps/QA
R6	Scope growth (additional connectors, document classes, tenant features).	4	3	12	Scope frozen at M1.1; change-request process (§12.10); add-on price list (§12.8).	Lead
R7	Key-person dependency in a five-person core team.	2	4	8	Documented architecture and ADRs; pairing on critical components; named deputy per role at kick-off; surge capacity arrangement (§10).	Lead
R8	GUI fallback agent brittle to target-application UI changes.	4	2	8	Used only where no API exists; deterministic selectors first; screenshot verification; allow-lists; dry-run; change detection to exception queue.	ML/VLM Eng.
R9	Data-residency or HIPAA constraints restrict a selected model API.	2	5	10	Residency captured at M1.1 before model selection is fixed; tokenization before external calls; regional endpoints; BAA confirmation (A-6); open-weight in-region fallback.	Lead / Client
R10	Kafka/ClickHouse ingestion lag at 5,000 events/s.	2	3	6	≥ 12 partitions; async inserts; lag alerts; ledger batching independent of the query tier; hot path never waits for persistence.	DevOps/QA
R11	SAML/Okta integration blocked by client IdP configuration.	3	3	9	IdP metadata and test tenant requested by week 12 (D-8); Keycloak broker tested against a mock IdP first.	Frontend / Client
R12	Working-hour overlap limits same-day decisions.	3	2	6	Daily overlap window 3–6 pm EAT (8–11 am EST) reserved for client decisions; decision log with 24-hour defaults.	Lead
R13	Regulatory change during delivery (e.g. EU AI Act timeline amendments, HIPAA Security Rule final text) alters the control map.	2	3	6	Control map is versioned data, not code; regulatory watch item in each steering meeting; changes absorbed as map updates within scope where no new system feature is required.	Lead
R14	Model deprecation, behaviour change or price change by an API provider mid-programme.	3	3	9	Model versions pinned and recorded per decision; evaluation harness detects behaviour drift; routing layer allows model swap per class without code change; open-weight fallback.	ML/VLM Eng.

9.1 Risk heat map

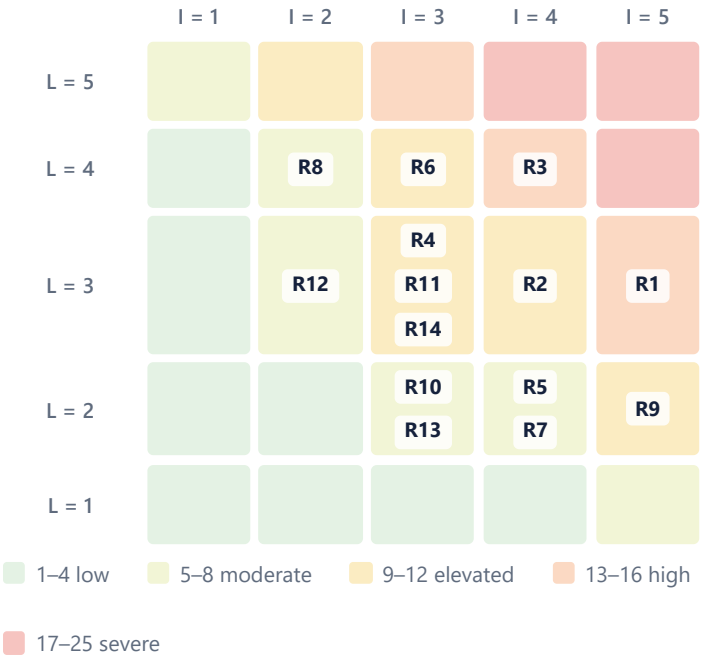


Figure 12 — Likelihood × impact heat map. Scores are the product L × I; cell shading follows the score bands in the legend.

Reading the map

Two risks sit in the high band (R1 accuracy on hard classes, R3 sandbox access) and four in the elevated band (R2, R4, R6, R11, R14 at 9–12). Each has a Phase 1 action that reduces it before Phase 2 begins: the stratified benchmark and accuracy definition (R1), the access request pack sent at kick-off with fixture-based fallbacks (R3), the per-stage latency budget enforced nightly (R2), the frozen scope baseline and change process (R6), and model pinning with a routing layer that allows swaps (R14). Residual scores are expected to fall to the moderate band by the end of Phase 1 and are re-scored at every phase gate.

Risks the Issuing Organization controls (R3, R9, R11, R12) are listed with the dependency date in §11 so that the mitigation is a calendar entry, not a hope.

10 Team Structure and Org Chart

A core team of five is assigned for the 24-week programme, led by the Solutions Architect / Project Lead, who is the single point of contact for the Issuing Organization and the authorised signatory. Individuals are confirmed to the Issuing Organization at contract signature; the roles, responsibilities and allocation below are the commitment. A named deputy for each role is confirmed at kick-off.

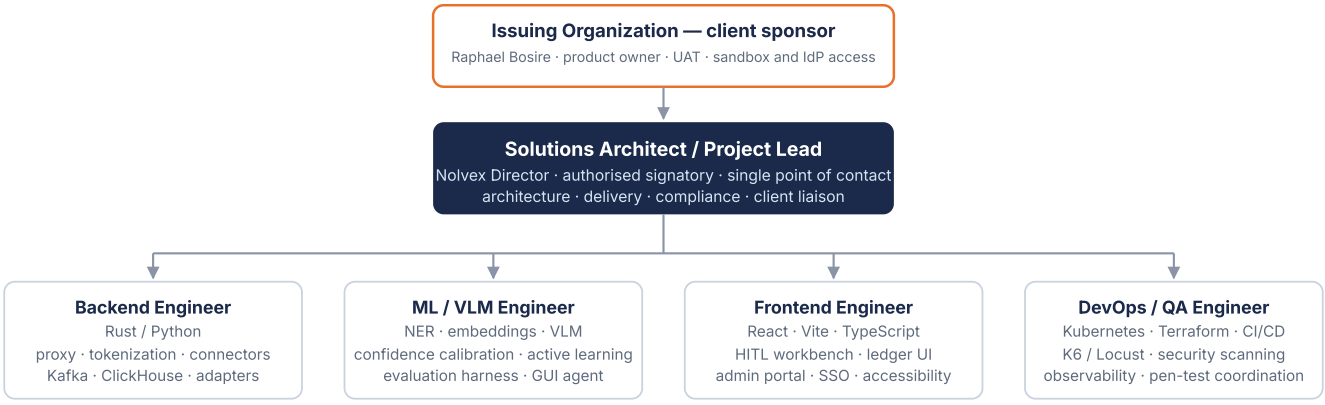


Figure 13 — Delivery team organisation. The Project Lead owns architecture, milestone acceptance and the compliance evidence index; each engineer owns the test levels for their components (§8.3).

Role	Responsibilities on this programme	Allocation (hours, §12.4)
Solutions Architect / Project Lead (Nolvex Director)	SAD and API contracts (M1.1), phase planning, milestone acceptance, risk and change management, compliance control map and evidence index, weekly reporting, steering meetings, client liaison.	330 h · all phases
Backend Engineer (Rust / Python)	Rust proxy and tokenization, connector crates, Kafka and ClickHouse integration, WORM ledger writer, compliance generator back end, Temporal activities, write-back adapters.	580 h · peak Phases 2–3
ML / VLM Engineer	NER and embedding model selection and serving, VLM extraction core, confidence calibration, active-learning memory, evaluation harness, CV GUI agent.	530 h · peak Phases 2 and 4
Frontend Engineer	HITL React/Vite workbench, ledger and compliance UI, multi-tenant admin portal, SAML/Okta integration, accessibility and end-to-end UI tests.	410 h · peak Phase 4
DevOps / QA Engineer	Terraform and Kubernetes environments, CI/CD, observability, K6/Locust load testing, security scanning, pen-test coordination, backup/DR, production rollout.	480 h · peak Phase 5

10.2 Continuity, surge capacity and working model

- **Continuity.** A named deputy per role, including the Project Lead, is confirmed at kick-off; documented architecture and ADRs, pairing on critical components and shared ownership of the CI gates reduce key-person risk (R7).
- **Surge capacity.** For Phase 4 (three parallel UI and ledger workstreams) and Phase 5 (UAT and remediation) Nolvex can add a second frontend engineer and a QA engineer from its bench at no change to the fixed price; the effort table in §12.4 is the planning basis, not a cap on what Nolvex will deploy to meet a milestone.
- **Working hours.** The team works from Nairobi (EAT, UTC+3). A guaranteed overlap window of 3:00–6:00 pm EAT (8:00–11:00 am EST) is held daily for client meetings, decisions and support; extended overlap is arranged for UAT (weeks 17–20) and production rollout (weeks 21–24), including on-call cover in the client's change windows.
- **Channels.** Shared Slack or Teams channel; weekly written status report; fortnightly steering meeting; phase-gate reviews; shared backlog and decision log (§7.4).
- **Escalation.** Project Lead → Nolvex Director (the same person on this engagement) → named deputy; client escalation path agreed at kick-off.

11 Assumptions, Dependencies and Client Responsibilities

11.1 Assumptions

ID	Assumption
A-1	The client provides cloud accounts (AWS or GCP) with quota for dev, test, staging and production, and pays infrastructure costs directly or as pass-through (§12.5).
A-2	The client provides sandbox access to Epic, Oracle Health (Cerner), NetSuite, Snowflake and AWS (CloudTrail) by the dates in §11.2, including any vendor app registration the client must initiate; delays shift dependent milestones by the same duration without changing the fixed price. Resource-level FHIR write support available in the client's instances is confirmed at M1.1 and the adapters are scoped to it.
A-3	The client provides API keys and quotas for the LLM/VLM providers it approves (including OpenAI and Anthropic for Track A, and the VLM used by Track B).
A-4	If VLM API quotas are insufficient for 1,000 docs/hr, the client makes GPU capacity available in its cloud account for an open-weight VLM; the switch is within scope.
A-5	The client supplies, or allows sampling of, at least 300 documents per document class with ground-truth labels (or labelling resources) by week 3. Two document classes are in scope and fixed at M1.1 (freight bill of lading and medical prior-authorisation request); further classes are add-ons (§12.8).
A-6	Business Associate Agreements with model and cloud providers and any data processing agreements are the client's responsibility; Nolvex will advise on which providers offer them.
A-7	Production deployment is to Kubernetes in the client's cloud account; Nolvex does not host client data.
A-8	Connector scope is the four Track A connectors and the Track B adapter families named in RFP §3 (FHIR for Epic / Oracle Health, NetSuite, SFTP, REST, SOAP, database sync); one legacy application is in scope for the GUI agent. Others are add-ons (§12.8).
A-9	Milestone acceptance or specific written rejection reasons are provided within 5 business days of delivery; otherwise the milestone is deemed accepted for invoicing.
A-10	The third-party penetration test is procured by the client, or by Nolvex as a pass-through at the client's election, and starts in week 17.
A-11	The client provides an Okta (or other SAML 2.0) test tenant and IdP metadata for SSO integration.
A-12	Usage-based billing metrics in the admin portal are metering and reporting only; invoicing or payment-gateway integration is out of scope unless added by change request.
A-13	The proof-of-capability demonstration (§7.3) uses synthetic or de-identified samples; any real data is processed only in an environment the client approves and deleted after the session.

11.2 Dependencies

ID	Dependency	Needed by	Affects
D-1	Cloud account access and IAM roles for Terraform	Week 1	M1.3
D-2	Benchmark document set and labels (or labelling resources)	Week 3	M1.1, M2.2
D-3	VLM API keys and quota	Week 4	M2.2
D-4	OpenAI and Anthropic API keys; Snowflake and CloudTrail sandbox credentials	Week 8	M3.1
D-5	Epic and Oracle Health (FHIR) and NetSuite sandbox credentials; SFTP test endpoint; vendor app registrations initiated	Week 8 (registrations from week 1)	M3.2

ID	Dependency	Needed by	Affects
D-6	Legacy GUI target application and test account	Week 9	M3.3
D-7	Control-mapping review by client compliance owner	Week 12	M4.2
D-8	Okta / SAML test tenant and IdP metadata; tenant and role model sign-off	Week 12	M4.3
D-9	Penetration-test vendor engaged and scope signed	Week 16	M5.2
D-10	UAT testers and user-story list; production account and change window	Weeks 16 / 20	M5.3, M6.1

11.3 Client responsibilities

- Nominate a product owner with authority to make scope and acceptance decisions within the overlap window.
- Provide the accounts, keys, sandboxes, IdP tenant and data listed above; provide subject-matter experts for document classes, target-system mappings and compliance control ownership.
- Review deliverables and respond to acceptance requests within 5 business days (A-9).
- Procure the penetration test and sign off its scope; execute UAT scripts; approve production deployment.
- Operate the systems after handover, or engage a maintenance retainer (§12.6).

12 Financial Proposal

All figures are in Kenya Shillings (KES) and exclude VAT. USD equivalents are shown at 1 USD = KES 129 for reference only; invoicing is in KES (§12.9). The commercial structure follows RFP §4: a fixed price per phase, invoiced on acceptance of the phase's final milestone, on the 15/20/20/20/15/10 schedule.

12.1 Pricing basis

- Fixed price per phase for professional services, delivered by the core team in §10 over 24 weeks (effort basis in §12.4); variation in actual effort does not change the price within the agreed scope.
- Open-source-first technology stack (§5.10); no software licence fees are embedded in the fixed price.
- Client-provided cloud and LLM/VLM API accounts (A-1, A-3); all third-party and infrastructure costs are pass-through at cost with supplier invoices attached (§12.5).
- Prices cover the scope defined in Sections 4–5 and RFP §2–§3; scope outside the RFP is handled by change request (§12.10) or the add-on list (§12.8).
- Prices are valid for 90 days from 26 October 2026.

12.2 Fixed-price summary

Option	Scope	Fixed price (KES, excl. VAT)	USD equiv.[1]
Track A only	Unified Active Audit — §5.1–5.3, all six phases incl. shared platform	1,800,000	13,953
Track B only	Zero-Template Autonomous Operator — §5.4–5.7, all six phases incl. shared platform	2,300,000	17,829
Combined Dual-System Package	**Track A + Track B, integrated, all six phases**	**3,900,000**	**30,233**

[1] At 1 USD = KES 129, rounded to the nearest dollar. The combined price is KES 200,000 (approximately 5%) below the sum of the two individual tracks (KES 4,100,000), reflecting shared Phase 1 architecture and environments, the shared admin portal (M4.3) and shared Phase 5–6 hardening, rollout and handover activities.

12.3 Phase payment schedule

Phase (RFP §4)	Trigger	%	Combined (KES)	Track A only (KES)	Track B only (KES)
1 Architecture & Security Setup	M1.3	15%	585,000	270,000	345,000
2 Differentiator Core Engines	M2.3	20%	780,000	360,000	460,000
3 Integrations & Execution Agents	M3.3	20%	780,000	360,000	460,000
4 HITL UI & Audit Systems	M4.3	20%	780,000	360,000	460,000
5 Hardening & Security Testing	M5.3	15%	585,000	270,000	345,000
6 Deployment & SLA Handover	M6.3	10%	390,000	180,000	230,000
Total		**100%**	**3,900,000**	**1,800,000**	**2,300,000**

For a single-track engagement the six phases and percentages are retained; milestones belonging to the other track (e.g. M2.2/M2.3 for Track A only) are replaced by the selected track's remaining scope, and the phase trigger becomes the last milestone of that track in the phase. Single-track milestone lists are confirmed at contract signature.

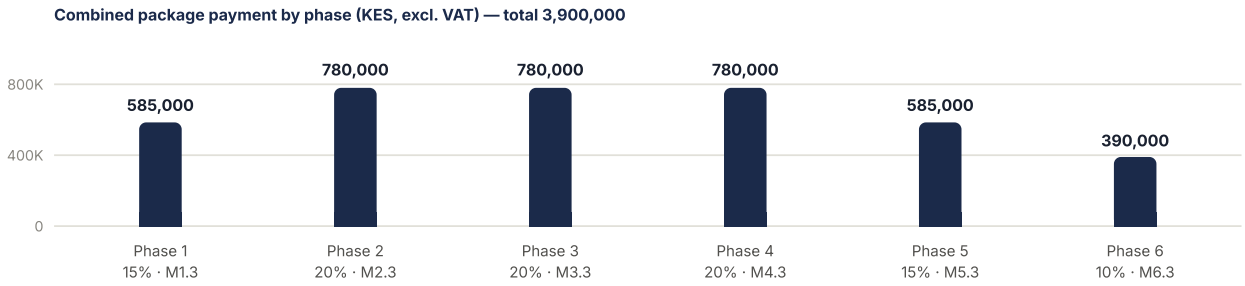


Figure 14 — Payment schedule by phase. Each bar is invoiced on acceptance of the phase's final milestone; the profile matches RFP §4 exactly.

12.4 Effort breakdown by role and phase (hours, combined package)

Role	Ph 1 w1–4	Ph 2 w5–8	Ph 3 w9–12	Ph 4 w13–16	Ph 5 w17–20	Ph 6 w21–24	Total
Solutions Architect / Lead	70	55	55	55	55	40	330
Backend Engineer (Rust/Python)	50	150	150	110	80	40	580
ML/VLM Engineer	40	150	100	110	80	50	530
Frontend Engineer	30	40	60	170	70	40	410
DevOps/QA Engineer	70	60	70	80	130	70	480
Total hours	**260**	**455**	**435**	**525**	**415**	**240**	**2,330**

Hours are the planning basis for the fixed price and are not billed separately; variation in actual effort does not change the fixed price within the agreed scope. Team members are allocated across phases as shown; surge capacity (§10.2) is deployed at Nolvex's cost where a milestone requires it.

12.5 Pass-through costs (excluded from the fixed price)

The following costs are not included in the KES 3,900,000 fixed price (nor in the single-track prices). They are billed at cost with supplier invoices attached, or paid by the client directly to the supplier. Indicative ranges are for budgeting; actuals depend on the client's choices and usage.

Item	When	Basis	Indicative (KES)
Accredited third-party penetration test (CREST or equivalent): external, internal, web application, API, SSO and cloud configuration review, plus one re-test and signed remediation verification (M5.2)	Phase 5	Auditor quotation; depends on auditor and scope	1,000,000 – 2,000,000
Cloud infrastructure during build (dev, test, staging: Kubernetes, Kafka, ClickHouse, S3, PostgreSQL, Redis, Temporal, observability) and LLM/VLM API usage for development, benchmark runs and load tests	Phases 1–6	Client cloud and API accounts; metered usage	400,000 – 800,000
Commercial licences, if elected instead of the self-hosted open-source default — e.g. Temporal Cloud, Amazon MSK, ClickHouse Cloud, commercial OCR	As elected	Vendor list price	At cost (optional)
Travel for on-site work, if requested	As requested	Economy fares and standard per diem, pre-approved	At cost (optional)

Indicative USD equivalents at KES 129: penetration test USD 7,750–15,500; build-phase infrastructure and API usage USD 3,100–6,200.

12.6 Ongoing costs after handover and SLA (M6.3)

Item	Scope	KES / month (excl. VAT)
Maintenance & support — Standard	Business hours 8 am–6 pm EAT, Mon–Fri. Response: Tier 1 (P1, production down) 4 h; Tier 2 (P2, degraded) next business day; Tier 3 (P3/P4) 3 business days. Monthly patching and dependency updates; up to 16 hours/month corrective and minor adaptive work; monthly service report incl. accuracy and latency trend.	60,000
Maintenance & support — Premium	24/7 coverage. Response: Tier 1 (P1) 1 h; Tier 2 (P2) 4 h; Tier 3 (P3/P4) next business day. Monthly patching; up to 32 hours/month corrective and adaptive work; quarterly accuracy and performance re-validation; model-version upgrade testing; monthly service report.	120,000
Client production cloud costs (pass-through)	Kubernetes nodes for proxy, semantic service, workflow, workbench and admin portal; Kafka; ClickHouse; S3 ledger storage; PostgreSQL; Redis; Temporal; observability; LLM/VLM API usage at production volumes.	Indicative 150,000 – 350,000[2]

[2] Indicative monthly estimate (USD 1,160–2,710) for a deployment sized to the RFP targets at moderate production volume; VLM API usage is the largest variable and scales with document volume. A sized estimate is provided at M1.3 and refined at M5.3. Retainers are optional, billed monthly in advance, minimum term 6 months, 30 days' notice; the SLA maintenance contract required at M6.3 is executed on one of these tiers or on the client's own support arrangement. The 90-day warranty (§12.10) applies regardless of retainer election.

12.7 Year-1 total cost of ownership (indicative, combined package)

RFP §5 asks for "predictable ongoing operational costs". The table below assembles every cost line in this proposal into a first-year view from contract start (six months of build, six months of operation) and a steady-state second year, so that the Issuing Organization can budget without reading the footnotes. All figures are KES excluding VAT; ranges reflect the indicative pass-through ranges above.

Cost line	Source	Year 1 — low	Year 1 — high	Year 2 (steady state)
Fixed professional-services price (both tracks)	§12.2	3,900,000	3,900,000	—
Penetration test (pass-through)	§12.5	1,000,000	2,000,000	optional annual re-test
Build-phase cloud and API usage (pass-through)	§12.5	400,000	800,000	—
Maintenance & support — Standard (6 months in Year 1; 12 in Year 2)	§12.6	360,000	360,000	720,000
Production cloud and API usage (6 months in Year 1; 12 in Year 2)	§12.6	900,000	2,100,000	1,800,000 – 4,200,000
Total with Standard support		**6,560,000**	**9,160,000**	**2,520,000 – 4,920,000**
Premium support instead of Standard (adds)	§12.6	+360,000	+360,000	+720,000
Total with Premium support		**6,920,000**	**9,520,000**	**3,240,000 – 5,640,000**

USD equivalents at KES 129: Year 1 with Standard support USD 50,853–71,008; with Premium support USD 53,643–73,798; Year 2 with Standard support USD 19,535–38,140. The dominant variable after go-live is VLM API usage, which is proportional to document volume and is reported per tenant in the admin console so it can be priced through to the client's own customers.

12.8 Optional add-ons (priced separately, not included in the fixed price)

Add-on	Scope	Price (KES, excl. VAT)
EU AI Act conformity documentation pack	Risk classification memo; technical documentation per Annex IV structure; data-governance, logging and human-oversight statements; post-market monitoring plan; built on the ISO 42001 artefacts and EU AI Act control-map entries delivered in the base scope (§6).	180,000
Additional Track A connector	One further connector beyond CloudTrail, Snowflake, OpenAI and Anthropic (e.g. Azure OpenAI, Google Vertex AI, Amazon Bedrock, Databricks), with contract tests and documentation.	90,000 per connector
Additional Track B write-back adapter	One further target beyond the RFP-listed families (e.g. SAP, Salesforce, QuickBooks, a payer prior-authorisation API), with sandbox testing.	120,000 per adapter
Additional legacy application for the GUI agent	Screen mapping, allow-lists and verification scenarios for one further application beyond the one in base scope.	90,000 per application
Additional document class (Track B)	Schema, benchmark labelling support, threshold calibration and accuracy report for one further class beyond those fixed at M1.1.	60,000 per class
Open-weight VLM fine-tuning (LoRA)	Supervised fine-tuning of an open-weight VLM on accumulated corrections for one document class, served in the client's cloud; includes evaluation against the held-out set.	150,000 per class
On-site training	Two-day on-site workshop for operators and administrators at the client's premises (up to 12 participants); travel billed as pass-through.	150,000 plus travel
Extended hypercare	Dedicated engineer availability during the overlap window for 4 weeks after M6.1, beyond warranty defect handling.	160,000

12.9 Payment terms

- **Invoicing.** Each phase is invoiced on acceptance of its final milestone (§12.3). Pass-through costs are invoiced monthly in arrears with supporting supplier invoices.
- **Terms.** Net 15 days from invoice date.
- **Retention.** 10% of each phase payment is held by the client until written phase sign-off, then released with the next invoice (or within 15 days of final sign-off for Phase 6).
- **VAT.** 16% VAT applies where applicable and is shown separately on each invoice. All prices in this proposal are VAT exclusive.
- **Currency.** Invoices are issued in KES. Payments made in foreign currency are converted at the Central Bank of Kenya indicative rate on the invoice date; bank charges on inbound foreign transfers are borne by the payer.
- **Payment methods.** Bank transfer; account details are provided on each invoice.
- **Late payment.** Work on the next phase may be paused if an accepted-milestone invoice is more than 15 days overdue; the schedule shifts by the duration of the pause.

Confidential —prepared for the Issuing Organization. ©2026 Nolvex.

12.10 Commercial terms

- **Intellectual property.** All deliverables developed under this engagement (source code, IaC, documentation, prompts, schemas, exemplar data, control maps, calibration models and any models fine-tuned on client data) are assigned to the client on receipt of final payment; until then the client holds a licence for evaluation, UAT and production use. Open-source components remain under their own licences (§5.10, SBOM). Nolvex retains the right to reuse generic, non-client-specific tooling and know-how.
- **Warranty.** 90 days from production deployment (M6.1). Defects in the delivered scope are corrected at no charge, including re-testing. Excluded: defects caused by client changes to code or infrastructure, third-party service changes, or use outside documented limits.
- **Change requests.** Scope outside the RFP and this proposal is handled by a written change request stating the change, schedule and price impact, and acceptance criteria; priced at the add-on rates in §12.8 where applicable, otherwise at a blended rate of KES 4,500 per hour; client sign-off before work starts.
- **Confidentiality.** Mutual non-disclosure covering client data, systems and this proposal; Nolvex personnel sign confidentiality undertakings; client data is processed only in client-controlled environments (A-7).
- **Acceptance.** Per Appendix A and Assumption A-9.
- **Termination.** Either party may terminate for uncured material breach on 30 days' written notice; the client may terminate for convenience at any phase gate, paying for accepted milestones and work in progress at the blended rate; deliverables to date are handed over.
- **Liability.** Nolvex's aggregate liability is limited to fees paid under the contract; neither party is liable for indirect or consequential loss. Subject to contract negotiation
- **Governing law.** Laws of Kenya unless otherwise agreed in the contract. Subject to contract negotiation

13 Appendices

A Acceptance criteria per milestone

Milestone	Acceptance criteria (all must be met)	Evidence
M1.1	SAD approved covering microservices, Kafka streams and proxy routing; OpenAPI 3.0 and gRPC contracts for ingestion middleware, guardrail checks and document-processing endpoints lint-clean and approved; benchmark manifest (classes, counts, splits, custody of the test split), control map, threat model and model selections delivered; document classes and connector scope frozen.	Signed SAD; contract repository; benchmark manifest; threat model
M1.2	PostgreSQL schemas, ClickHouse event-store DDL, Redis queue structures, Kafka topic/partition topology and Temporal state-machine blueprints reviewed and versioned.	Schema repository; design review minutes
M1.3	Terraform applies cleanly from a clean account to a staging EKS/GKE cluster; CI pipeline runs on a sample PR with coverage, security and accessibility gates active; Argo CD deploys a sample service.	Terraform logs; CI run links
M2.1	Masking of agreed PII/PHI/PCI classes verified on the test corpus (deterministic and semantic detection) with precision and recall reported; p99 < 50 ms at 1,000 req/s in staging under K6; context-preservation benchmark ≥ 97% equivalence; fail-closed on timeout verified; streaming re-hydration verified.	K6 report; masking and context reports
M2.2	Extraction core returns schema-valid JSON with provenance for all document classes incl. handwritten samples; end-to-end accuracy > 95% and auto-approved precision ≥ 97% on the held-out split (§5.8.2); calibration report with expected calibration error ≤ 0.05.	Accuracy and calibration harness report
M2.3	Workflow completes the lifecycle for sample documents incl. retry, timeout, review-signal and exception paths; survives worker restart mid-flow; Redis queue absorbs a burst test; workflow versioning demonstrated with in-flight documents.	Temporal history; test report
M3.1	Each of CloudTrail, Snowflake, OpenAI and Anthropic connectors proxies or ingests representative traffic in staging with masking applied and audit events on Kafka; streaming and tool-call payloads covered; contract tests pass.	Demo; test reports
M3.2	FHIR (Epic, Oracle Health), NetSuite and SFTP adapters each commit and read back a record in the client sandbox; REST, SOAP and database-sync adapters pass contract tests; compensation path tested.	Sandbox records; test report
M3.3	GUI agent completes the agreed write-back scenario against the legacy application with screenshot verification; dry-run, allow-list enforcement and change-detection diversion demonstrated.	Recording; test report
M4.1	Reviewers can claim, correct, annotate, approve and reject with keyboard-only operation; provenance highlight works; "approve and retrain" stores the exemplar, re-runs the harness and updates routing and thresholds; a correction demonstrably changes the next similar extraction; golden-document QA active; WCAG 2.1 AA automated checks pass.	Demo; Playwright E2E report; harness delta
M4.2	Ledger UI queries events by tenant, period and control; one-click PDF and CSV packages generated for ISO 42001, HIPAA, SOC 2 and EU AI Act views; hash-chain verification detects a tampered batch and a gap in a test; S3 Object Lock compliance mode, retention and legal hold confirmed; external timestamp anchoring verified.	Sample packages; verification output
M4.3	Tenant creation and isolation verified by test; RBAC roles enforced in API and UI; SAML 2.0 login via the client's Okta test tenant with group-to-role mapping; usage metrics per tenant displayed and exportable.	Demo; isolation test report
M5.1	SOC 2 Type II and HIPAA control-by-control evidence index delivered with no open gaps; backup/restore and ledger recovery demonstrated within 72 hours; residency verified; ePHI data-flow inventory produced.	Evidence index; DR log
M5.2	Penetration test report delivered; all High and Critical findings remediated and confirmed by signed auditor re-test; Medium/Low addressed or risk-accepted in writing.	Pen-test and remediation reports

Milestone	Acceptance criteria (all must be met)	Evidence
M5.3	K6: 7,500 req/s for 30 min with p99 < 50 ms and no event loss; Locust: 2,000 documents in 2 hours; accuracy re-validated per §5.8.2; all UAT user stories executed with zero open S1/S2; UAT sign-off form signed.	K6/Locust scripts and reports; UAT sign-off
M6.1	Production deployment completed in the client's change window on HA Kubernetes behind production API gateways; smoke tests pass; monitoring and alerting live; rollback rehearsed.	Go-live report
M6.2	Source code, IaC and build repositories transferred; coverage ≥ 85% per repository; runbooks, infrastructure maintenance guides, API developer documentation and SDK references, end-user and administrator manuals delivered; SBOMs for all releases.	Repository transfer record; coverage reports; document set
M6.3	Operational training sessions delivered and attended; SLA maintenance contract executed; warranty start date confirmed in writing; access revocation confirmed.	Attendance record; signed SLA

B Glossary

Term	Definition
Unified Active Audit	Track A: the proxy, semantic tokenization, event and WORM-ledger platform described in §5.1–5.3 (RFP §1 System #1).
Zero-Template Autonomous Operator	Track B: the template-free document extraction, HITL and write-back platform described in §5.4–5.7 (RFP §1 System #2).
Semantic tokenization	Replacement of a sensitive value with a token encoding its entity type, semantic role and a session-consistent identifier so that downstream models retain reasoning capability; reversible only for authorised consumers.
PII / PHI / PCI	Personally identifiable information; protected health information; payment-card information.
WORM	Write-once-read-many storage; implemented with S3 Object Lock in compliance mode as the authoritative copy and an append-only ClickHouse store for query.
Hash chain / Merkle root	Each ledger batch records the SHA-256 digest of the previous batch and a Merkle root of its events so that modification, deletion or re-ordering is detectable.
RFC 3161 timestamp	A signed time-stamp token from a trusted authority proving that a hash existed at a point in time; used to anchor the chain head.
VLM	Vision-language model: accepts page images and text prompts and returns structured text.
Calibrated confidence	A probability per field, fitted on held-out data, that a value is correct; the 95% gate is applied to this probability, and its error (expected calibration error) is reported.
HITL	Human-in-the-loop: reviewer intervention on fields below the 95% confidence threshold.
Active learning	Automatic feeding of reviewer corrections into prompt exemplars, routing rules and thresholds.
STP	Straight-through processing: documents completed without any human touch.
Temporal.io	Durable-execution workflow engine used for the Track B state machine and retry logic.
FHIR / HL7 / Da Vinci PAS	Fast Healthcare Interoperability Resources, the HL7 API standard used for Epic and Oracle Health write-back; Da Vinci PAS is the HL7 implementation guide for prior-authorisation submission.
RBAC / SSO / SAML 2.0	Role-based access control; single sign-on; the federation standard used with Okta for the admin portal.
p99	99th-percentile value of a latency distribution.
SBOM	Software bill of materials listing all components and versions in a release.
Pass-through	A cost invoiced at supplier price without margin, or paid directly by the client.

Term	Definition
EAT / EST	East Africa Time (UTC+3) / US Eastern Standard Time (UTC−5).

C Compliance control mapping (sample rows)

Sample rows from the control map delivered at M1.1, implemented in the compliance generator (M4.2) and evidenced at M5.1. The full map lists every applicable control; control identifiers follow the current editions cited in §6.1.

Framework	Control	System feature	Evidence
ISO/IEC 42001	6.1.2 AI risk assessment; 6.1.4 / A.5 AI system impact assessment	Model cards and impact-assessment template (ISO/IEC 42005-aligned) for NER, embedding and VLM models; risk register (§9).	Model cards; impact assessments; register
ISO/IEC 42001	A.6.2.6 AI system operation and monitoring	Accuracy-drift dashboard; nightly harness; alerting; calibration refit log.	Grafana dashboards; harness reports
ISO/IEC 42001	A.6.2.8 Recording of event logs	Model version, prompt hash, policy version and decision recorded per request/document in the WORM ledger.	Ledger schema; sample export
ISO/IEC 42001	A.9.2 / A.9.4 Responsible use; intended use	Intended-use statements per document class and route; 95% confidence threshold with reviewer override; GUI agent dry-run and allow-lists.	Use statements; HITL logs; config
ISO/IEC 42001	A.10 Third-party and customer relationships	Provider inventory with regions, BAAs and model versions; routing layer records provider per decision.	Provider register; ledger
HIPAA	§164.312(a)(1) Access control	SSO with MFA, RBAC, least-privilege IAM, workload identity, tenant row-level security.	IAM policies; role matrix
HIPAA	§164.312(b) Audit controls; §164.308(a)(1)(ii)(D) Activity review	Immutable WORM ledger of every PHI access, tokenization, re-hydration and write-back; scheduled review reports.	Ledger verification report; review log
HIPAA	§164.312(c)(1) Integrity	Hash-chained batches; Object Lock compliance mode; RFC 3161 anchors.	Hash verification tool output
HIPAA	§164.312(e)(1) Transmission security	TLS 1.3; PHI tokenised before external model calls; regional endpoints.	TLS config; masking tests
HIPAA	§164.308(a)(7) Contingency plan; §164.316(b)(2) Retention	Backup and 72-hour restoration demonstrated; six-year ledger retention by default.	DR log; retention config
SOC 2	CC6.1 Logical access; CC6.6/CC6.7 Boundaries and encryption	RBAC, MFA via SSO, secrets in Vault / Secrets Manager; KMS encryption; network policies.	Access review; Vault audit log
SOC 2	CC7.2 Anomaly monitoring; CC7.3 Evaluation of security events	Prometheus alerts on latency, lag, error rate, accuracy drift; incident runbooks; ledger as event record.	Alert rules; incident log
SOC 2	CC8.1 Change management; PI1.4 Processing integrity	GitOps with reviewed, signed commits; Argo CD history; SBOM per release; accuracy gates and reviewer records.	PR history; Argo CD audit; harness reports
EU AI Act	Art. 9 Risk management; Art. 10 Data governance	Risk register tied to model cards; benchmark provenance and bias checks per class.	Register; benchmark manifest
EU AI Act	Art. 12 Record-keeping; Art. 14 Human oversight	Per-decision logging in the ledger; HITL thresholds and override; exportable logs by period.	Ledger export; HITL config

Framework	Control	System feature	Evidence
EU AI Act	Art. 13 Transparency; Art. 15 Accuracy and robustness; Art. 17 QMS	Deployer documentation and decision explanations; accuracy and calibration reporting; QMS artefacts aligned to EN 18286:2026.	Documentation set; harness reports
Colorado SB 26-189	Notice; adverse-decision disclosure; human review; record-keeping	Decision record with explanation per document; reviewer identity and outcome; retention.	Ledger export; workbench logs

D RFP requirements compliance checklist

RFP ref.	Requirement	Compliance	Proposal section
§1	Combined Dual-System Development Package; Track A and Track B options	**Complies**	§2, §4, §12.2
§2 A	Sub-50 ms proxy engine, Rust/Python, streaming payloads, semantic context preserved	**Complies**	§5.1, §5.2, §5.8.1, M2.1
§2 A	Semantic tokenization of PII/PHI/PCI using contextual embeddings	**Complies**	§5.2, §5.10
§2 A	WORM append-only ledger in ClickHouse / S3 Object Lock; audit packages .PDF/.CSV	**Complies**	§5.3, App. F, M4.2
§2 A	Mapping to ISO 42001, HIPAA, EU AI Act, SOC 2	**Complies**	§6, App. C
§2 B	Zero-template VLM extraction incl. handwritten and variable layouts	**Complies**	§5.4, §5.5, §5.8.2, M2.2
§2 B	Temporal state machine and retry logic	**Complies**	§5.7, M2.3
§2 B	Closed-loop HITL below 95% confidence; corrections fed to prompt/routing memory	**Complies**	§5.5, §5.6, §5.9, M4.1
§2 B	Hybrid execution: FHIR/REST/SOAP write-back with CV browser-automation fallback	**Complies**	§5.7, M3.2, M3.3
§3 P1	SAD; OpenAPI 3.0 / gRPC contracts; PostgreSQL, ClickHouse, Redis data model; Terraform for EKS/GKE; CI/CD to staging	**Complies**	§5.10, §7.1, §8, App. G, M1.1–M1.3
§3 P2	Tokenization proxy under stress; VLM engine > 95%; Temporal workflow engine	**Complies**	§5.8, M2.1–M2.3
§3 P3	Connectors CloudTrail, Snowflake, OpenAI, Anthropic; adapters Epic/Cerner FHIR, NetSuite, SFTP, REST, SOAP, DB sync; GUI fallback agent	**Complies**	§5.1, §5.7, M3.1–M3.3
§3 P4	HITL React/Vite app with side-by-side validation, annotation, one-click retraining; WORM ledger interface with one-click export; multi-tenant admin portal with RBAC, SAML 2.0 / Okta SSO, usage-based billing metrics	**Complies** (A-12)	§5.6, §5.9, M4.1–M4.3
§3 P5	SOC 2 Type II and HIPAA audit readiness; third-party pen test with zero unresolved High/Critical and signed remediation; K6/Locust benchmarks; UAT sign-off	**Complies** (pen-test cost pass-through)	§6, §8, §12.5, M5.1–M5.3
§3 P6	HA Kubernetes production deployment behind API gateways; source code, IaC and docs with coverage > 85%; runbooks, API/SDK docs, user and admin manuals; training; SLA contract with Tier 1–3 response times	**Complies**	§5.8.4, §7.1, §12.6, M6.1–M6.3
§4	Six phases over 24 weeks; payment 15/20/20/20/15/10	**Complies**	§7, §12.3
§5 (30%)	Demonstration of sub-50 ms masking, zero-template extraction, active-learning HITL	**Addressed**	§2.2, §5, §7.3
§5 (25%)	Industry track record	**Addressed**	§2.4, §10, App. E
§5 (20%)	Fixed-price phase breakdown; predictable ongoing operational costs	**Addressed**	§12.2–12.7

RFP ref.	Requirement	Compliance	Proposal section
§5 (15%)	Security posture and compliance preparedness	Addressed	§6, App. C, App. F
§5 (10%)	Execution plan realism, risk management, team qualifications	Addressed	§7, §9, §10, §11
Cover	Submission by 20 Nov 2026, 5:00 PM EST to bosire73@gmail.com; 90-day validity	Complies	Cover, §1, §12.1

E Company details and references

Item	Detail
Contracting entity	Nolvex, Nairobi, Kenya. Company registration and tax particulars are provided with the contract documents at award.
Registered address	Suite 405, 4th Floor, 2129 Office Suites, 69 Muthithi Road, Westlands, Nairobi, Kenya
Authorised signatory	David Ngeiywa, Director · +254 714 985 264 · david@dta.co.ke

Relevant project references (RFP §5, Industry Track Record)

Each referee has agreed to be contacted; direct e-mail and telephone details are supplied on request to the Issuing Organization so that they are not circulated with the proposal document. Scope statements describe work the Nolvex team delivered; where a platform is still in build, that is stated.

#	Referee and organisation	Period	Scope and technologies
1	Timothy — Novatrix (franchise group: Freitex, Movafy, TenantSpace, KIFWA portal)	Aug 2026 – present	**Freitex**, the multi-tenant clearing-and-forwarding platform of the Novatrix group: quotations, jobs, customs clearance, client portal and payments for agents across Africa, built country-neutral from the first row. Laravel 12, PostgreSQL 17, Inertia 2 with React 19 and TypeScript, Vite, Docker. Also the **KIFWA member portal** for the Kenya International Freight & Warehousing Association (Sep 2026). Directly relevant to Track B's freight bills of lading and multi-tenant operation.
2	Kennedy Ndigwa — Werezi	Nov 2022 – present	**Werezi Books**, a production online bookstore on Laravel with a catalogue of several hundred thousand titles fed from a vendor data feed, inventory and contributor data pipelines, a documented design system, Forge-managed hosting and a read-only production data-sync tooling for safe development. Evidence of a shipped, maintained enterprise web platform with continuous delivery.
3	Aggrey Lutsinga — Digital Tailor Agency	Nov 2024 – present	**Thrive HRMIS**: a production human-resource management system (Laravel back end with scheduled jobs) with a Flutter employee app and a kiosk app, handling employee personal data under role-based access. **MarketPilot AI suite** (2025 – 2026): a TypeScript workflow and integration platform with webhook reconciliation across connected accounts, per-store write-back adapters and audited report metrics. Relevant to the RBAC, PII handling and adapter patterns in both tracks.

F Sample audit package (concept)

A concept of the first pages of a one-click package generated by the compliance generator (§5.3, Figure 8). Values are illustrative; the layout is finalised with the client's compliance owner at M4.2.

UNIFIED ACTIVE AUDIT · EVIDENCE PACKAGE

ISO/IEC 42001:2023 — Controls Evidence Report

Tenant: Meridian Health · Period: 1 Jul 2026 – 30 Sep 2026 · Generated: 2026-10-01 00:06 UTC · Package ID: PKG-2026-Q3-ISO42001-0142

CHAIN VERIFICATION: PASS

Batches 18,221 – 24,907 · 6,687 sealed
Head anchor: RFC 3161 TSA 2026-10-01T00:05:12Z
Package SHA-256: 9f2c…71ae

Controls in scope	Evidenced	Partial / open	Events referenced
39	38	1	14.2M

1. Control coverage matrix (excerpt)

Control	Title	Status	Evidence events	Owner	Sample refs
A.6.2.8	Recording of event logs	Evidenced	14,206,118	Platform	EV-7f3a..., EV-81c0..., +3
A.6.2.6	AI system operation and monitoring	Evidenced	92 (nightly harness runs)	ML Ops	HR-2026-09-30, +4
A.9.4	Intended use of AI system	Evidenced	6 (use statements, 2 routes · 4 classes)	Compliance owner	US-PA-v3, US-BOL-v2, +4
A.5.4	AI system impact assessment	Partial	3 of 4 classes assessed	Compliance owner	IA-PA-v2, IA-BOL-v1, IA-CLN-v1 · open: IA-INV

2. Evidence sample — A.6.2.8 (1 of 5)

```
event_id: EV-7f3a9c21e · ts: 2026-09-14T13:42:07.118Z · tenant: meridian · class: mask.decision · route: /v1/chat→anthropic policy: v14 · model: claude-sonnet-5.5 (pinned 2026-09-01) · prompt_hash: 3e1b…9d · spans: 14 (PHI 11, PII 2, PCI 1) · actions: tokenize 12 · shift 1 · irreversible 1 latency_ms: {auth: 2.1, det: 4.0, sem: 18.6, rewrite: 3.3, total: 29.4} · rehydrate_allowed: [clinical-summary-svc] · batch: 22,118 · merkle_leaf: a71c…04
```

Attestation: generated automatically from the WORM ledger; chain re-verified at generation; no events were excluded. Verification instructions and the open-source verifier are in Annex 4 of this package. Page 1 of 148

Figure 15 — Sample audit package, first page (concept). The same generator produces HIPAA, SOC 2 and EU AI Act views from the same ledger; the CSV companion contains the full evidence list for the auditor's tooling.

G API contract excerpt (OpenAPI 3.0, illustrative)

An excerpt of the style of contract delivered at M1.1 for the Track A guardrail endpoint and the Track B document endpoint. Full contracts are lint-clean (Spectral) and versioned with breaking-change checks (buf for gRPC).

```
# Track A — guardrail proxy (excerpt)
paths:
  /v1/guard/chat:
    post:
      summary: Mask and dispatch a chat completion to the route's upstream model
      parameters:
        - { name: X-Tenant-Id, in: header, required: true, schema: { type: string } }
        - { name: X-Route, in: header, required: true, schema: { type: string, example: anthropic-prod } }
        - { name: X-Consumer-Purpose, in: header, required: false, schema: { type: string } }
      requestBody: { $ref: '#/components/requestBodies/ChatRequest' }   # provider-shaped body passes through
      responses:
        '200': { description: Upstream response, re-hydrated if the caller is authorised; SSE when stream=true }
        '422': { description: Blocked by policy (fail-closed or entity class set to block) }
        '504': { description: Semantic stage missed its deadline and the route policy is reject }
      x-nolvex-sla: { masking_p99_ms: 50, measured_at: proxy, excludes: upstream }
      x-nolvex-audit: { event_class: mask.decision, controls: [ISO42001:A.6.2.8, HIPAA:164.312(b), SOC2:CC7.2,
EUAIA:Art12] }

# Track B — document intake (excerpt)
  /v1/documents:
    post:
      summary: Submit a document for template-free extraction and downstream write-back
      requestBody:
        content:
          multipart/form-data:
            schema:
              properties:
                file:          { type: string, format: binary }
                schema_id:     { type: string, nullable: true, description: Omit to auto-detect the document class }
                priority:      { type: string, enum: [expedited, standard], default: standard }
                target:        { type: string, enum: [fhir-epic, fhir-oracle, netsuite, sftp, rest, soap, gui],
nullable: true }
      responses:
        '202': { description: Accepted; returns workflow_id and a status URL }
  /v1/documents/{workflow_id}:
    get:
      responses:
        '200':
          content:
            application/json:
              schema:
                properties:
                  state:   { type: string, enum: [INGESTED, PREPROCESSED, EXTRACTED, SCORED, IN_REVIEW, APPROVED,
WRITTEN_BACK, VERIFIED, DONE, EXCEPTION] }
                  fields:  { type: array, items: { $ref: '#/components/schemas/ExtractedField' } }
components:
  schemas:
    ExtractedField:
      properties:
        name:        { type: string }
        value:       { }
        confidence:  { type: number, minimum: 0, maximum: 1, description: Calibrated probability the value is correct }
        provenance:  { type: object, properties: { page: { type: integer }, bbox: { type: array, items: { type: number
}, minItems: 4, maxItems: 4 } } }
        decision:    { type: string, enum: [auto_approved, review, corrected] }
        model:       { type: string, description: Model identifier and version pinned for this decision }
```

H Sources and references

All sources were accessed on 22 October 2026 unless a publication date is given. Vendor-published figures are marked where no independent confirmation exists.

[1] Vanta, "Vanta crosses $300M in ARR as growth accelerates", 29 Apr 2026. vanta.com/resources/vanta-crosses-300m-in-arr-as-growth-accelerates

[2] Vanta, "Introducing AI Governance from Vanta", 30 Jul 2026. vanta.com/resources/introducing-ai-governance-from-vanta

[3] Forrester Wave: Governance, Risk and Compliance Platforms, Q2 2026 (via BusinessWire, 20 May 2026). secure.businesswire.com/news/home/20260520855495/en/

[4] Drata, AI Agent Governance limited availability (BusinessWire, 4 Aug 2026). businesswire.com/news/home/20260804704925/en/

[5] Help Net Security, "Drata AI Agent Governance", 10 Jun 2026. helpnetsecurity.com/2026/06/10/drata-ai-agent-governance/

[6] Protecto, product and agentic-AI pages (vendor). protecto.ai

[7] Lakera, sizing guide (p95 < 20 ms at 1,000 characters, self-hosted; vendor). docs.lakera.ai/docs/sizing-guide; Check Point acquisition of Lakera, 16 Sep 2025. itsecurityguru.org/2025/09/17/check-point-acquires-ai-security-company-lakera/

[8] Palo Alto Networks completes acquisition of Protect AI, 22 Jul 2025. paloaltonetworks.com/company/press/2025/...; Portkey acquisition, 29 May 2026. intelligencecommunitynews.com/palo-alto-acquires-portkey/

[9] SentinelOne Form 10-Q (Prompt Security acquisition closed 5 Sep 2025). sec.gov/Archives/edgar/data/1583708/000158370825000159/s-20251031.htm

[10] Nightfall, "Nightfall launches MCP Gateway", 9 Sep 2026. nightfall.ai/news/nightfall-launches-mcp-gateway-to-govern-ai-agents-before-they-act

[11] AWS, Amazon Bedrock Guardrails — sensitive information filters. docs.aws.amazon.com/bedrock/latest/userguide/guardrails-sensitive-filters.html

[12] DeepInspect, "AI audit log immutability", 19 Aug 2026. deepinspect.ai/blog/ai-audit-log-immutability

[13] ABBYY Vantage documentation, "Introduction" (skills). docs.abbyy.com/vantage/introduction; ABBYY, Phoenix Plus press release, 20 Oct 2026 (GlobeNewswire).

[14] UiPath Document Understanding user guide, "Build" (≥ 150 documents per document type). docs.uipath.com/document-understanding/automation-cloud/latest/user-guide/build; IXP FAQ. docs.uipath.com/ixp/automation-cloud/latest/user-guide/faq

[15] Forrester, "Findings from The Forrester Wave: Document Mining and Analytics Platforms, Q2 2026", 21 May 2026. forrester.com/blogs/findings-from-the-forrester-wave-document-mining-and-analytics-platforms-q2-2026/

[16] Gartner, "Gartner predicts over 40% of agentic AI projects will be canceled by end of 2027", 25 Jun 2025. gartner.com/en/newsroom/press-releases/2025-06-25-...

[17] Coupa acquires Rossum, 12 May 2026 (PR Newswire).

[18] Gartner, "Gartner forecasts the market for securing AI will reach almost $5 billion in 2027", 26 Aug 2026. gartner.com/en/newsroom/press-releases/2026-08-26-...

[19] Gartner via Nemko, "AI governance platforms market to surpass $1 billion by 2030", Feb 2026. digital.nemko.com/news/ai-governance-platforms-market-to-surpass-1-billion-by-2030

[20] Global Market Insights, Intelligent Document Processing Market; Research and Markets, IDP market report (2026 estimates USD 3.6–4.4 billion).

[21] Microsoft Presidio releases (2.2.364, 22 Jul 2026). github.com/microsoft/presidio/releases

[22] A. Sikkema, "Benchmarking open-source PII detection", 1 Jun 2026 (independent). albertsikkema.com/python/security/privacy/2026/06/01/benchmarking open-source-pii-detection.html

[23] P. Schmid, "Optimizing Transformers with Hugging Face Optimum" (ONNX int8 DistilBERT latency), 30 Jun 2022. philschmid.de/optimizing-transformers-with-optimum

[24] GLiNER2-PII, arXiv:2605.09973, 11 May 2026.

[25] Pasch and Cha, "Entity-typed placeholders and LLM task quality", PrivateNLP 2025. aclanthology.org/2025.privatenlp-main.3/

[26] Deusser et al., "Anonymisation and LLM performance across 11 benchmarks", arXiv:2609.11335, 10 Sep 2026.

[27] Cloudflare, "How we built Pingora, the proxy that connects Cloudflare to the Internet", 14 Sep 2022. blog.cloudflare.com/how-we-built-pingora-...

[28] TechEmpower, Framework Benchmarks Round 23, 17 Mar 2025. techempower.com/blog/2025/03/17/framework-benchmarks-round-23/

[29] ClickHouse, ClickPipes for Kafka best practices. clickhouse.com/docs/integrations/clickpipes/kafka/best-practices; Mux, "Latency and throughput trade-offs of the ClickHouse Kafka table engine". mux.com/blog/...

[30] AWS, Amazon S3 Object Lock. docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html; S3 performance design patterns. docs.aws.amazon.com/AmazonS3/latest/userguide/optimizing-performance.html

[31] AWS, Amazon QLDB end of support (31 Jul 2025). docs.aws.amazon.com/qldb/latest/developerguide/what-is.html

[32] IETF RFC 3161, Time-Stamp Protocol. rfc-editor.org/rfc/rfc3161

[33] OpenDataLab, OmniDocBench (v1.6 leaderboard, updated 11 Sep 2026). github.com/opendatalab/OmniDocBench

[34] Ai2, olmOCR and olmOCR-bench. github.com/allenai/olmocr

[35] "Handwritten medical form extraction with current VLMs", arXiv:2604.16504, 14 Apr 2026.

[36] WildHandBench, arXiv:2608.22959, 24 Aug 2026.

[37] Xiong et al., "Can LLMs express their uncertainty?", ICLR 2024, arXiv:2306.13063.

[38] ConfBench, arXiv:2608.01792, 3 Aug 2026.

[39] "Straight-through processing with conformal risk control for document extraction", arXiv:2609.20110, 17 Sep 2026.

[40] ExtractConf, arXiv:2606.24420, 23 Jun 2026.

[41] Temporal, server releases (v1.32.1, 8 Oct 2026). github.com/temporalio/temporal/releases; Temporal Cloud overview and pricing. docs.temporal.io/cloud/overview;

docs.temporal.io/cloud/pricing; "A year of change", Mar 2026. temporal.io/blog/a-year-of-change-a-foundation-for-whats-next

[42] Anthropic, computer use tool documentation. platform.claude.com/docs/en/agents-and-tools/tool-use/computer-use-tool; "Claude Sonnet 5.5", 28 Sep 2026. anthropic.com/news/claude-sonnet-5-5

[43] OpenAI, "Computer-Using Agent", Jan 2025. openai.com/index/computer-using-agent/

[44] Playwright release notes (1.64). playwright.dev/docs/release-notes

[45] Kong Gateway changelog (open-source line frozen at 3.9.x). developer.konghq.com/gateway/changelog/; Envoy Gateway releases. gateway.envoyproxy.io/news/releases/

[46] Release pages: Grafana k6 (github.com/grafana/k6/releases); Locust (pypi.org/project/locust/); React (github.com/facebook/react/releases); Vite (npmjs.com/package/vite); Keycloak 26.8 (keycloak.org/2026/10/keycloak-2680-released); pgvector (github.com/pgvector/pgvector); ONNX Runtime (github.com/microsoft/onnxruntime/releases); pdf.js (github.com/mozilla/pdf.js/releases).

[47] Model pricing pages: Anthropic (platform.claude.com/docs/en/about-claude/pricing); Google Gemini API (ai.google.dev/gemini-api/docs/pricing; document processing: 258 tokens per PDF page); OpenAI (developers.openai.com/api/docs/pricing); Mistral OCR 3 (mistral.ai/news/mistral-ocr-3).

[48] Reducto pricing (reducto.ai/pricing); Extend pricing (extend.ai/pricing); LlamaCloud pricing (developers.llamaindex.ai/llamaparse/general/pricing/).

[49] Hypatos, invoice processing accuracy benchmarks, May 2026 (vendor); Ardent Partners touchless-processing figures via Parseur.

[50] TrueFoundry, "PII redaction: LLM gateway vs application" (latency tiers; vendor). truefoundry.com/blog/pii-redaction-llm-gateway-vs-application; Occludra and Guardion vendor latency claims (unverified).

[51] Future of Privacy Forum, "The AI Act implementation timeline: what changes under the AI Omnibus", 5 Aug 2026. fpf.org/blog/the-ai-act-implementation-timeline-what-changes-under-the-ai-omnibus/

[52] Hunton, "EU Digital Omnibus on AI enters into force", 28 Jul 2026 (Regulation (EU) 2026/1744, OJ L 24 Jul 2026). hunton.com/privacy-and-cybersecurity-law-blog/eu-digital-omnibus-on-ai-enters-into-force

[53] European Commission, General-Purpose AI Code of Practice (updated 7 Oct 2026). digital-strategy.ec.europa.eu/en/policies/contents-code-gpai

[54] CEN-CENELEC, "EN 18286:2026 published in the OJEU", 15 Oct 2026. cencenelec.eu/news-events/news/2026/...

[55] EU AI Act Explorer (Articles 9–15, 17, 99; Annex IV). artificialintelligenceact.eu/ai-act-explorer/

[56] Federal Register, "HIPAA Security Rule to Strengthen the Cybersecurity of Electronic Protected Health Information" (NPRM), 6 Jan 2025, 90 FR 898.

[57] Davis Wright Tremaine, "HHS updates HIPAA rulemaking timeframes", 8 Jul 2026. dwt.com/blogs/privacy--security-law-blog/2026/07/hhs-updates-hipaa-rulemaking-timeframes

[58] Haynes Boone, "HIPAA reproductive healthcare privacy rule remains vacated after appeals closed", 2025.

[59] ISO/IEC 42001:2023 (iso.org/standard/42001); ISO/IEC 42005:2025 (iso.org/standard/44545.html); ISO/IEC 42006:2025 (BSI Knowledge catalogue).

[60] BSI, "BSI becomes the first certification body accredited by UKAS and RvA to deliver certification for ISO/IEC 42001", 17 Nov 2025.

[61] Anthropic, ISO 42001 certification, 13 Jan 2025 (anthropic.com/news/anthropic-achieves-iso-42001-certification-for-responsible-ai); AWS ISO 42001 FAQs (aws.amazon.com/compliance/iso-42001-faqs/); Microsoft ISO 42001 offering page (learn.microsoft.com/en-us/compliance/regulatory/offering-iso-42001).

[62] AICPA, 2017 Trust Services Criteria with Revised Points of Focus — 2022. aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022

[63] NIST AI Risk Management Framework (nist.gov/itl/ai-risk-management-framework); NIST AI 600-1 (Jul 2024); NIST CSF 2.0 (Feb 2024).

[64] Finnegan, "Colorado replaces landmark AI Act: an overview of the new SB 26-189 framework", 2026; Colorado Attorney General, AI page (coag.gov/ai/).

[65] K&L Gates, "Pared-back version of the Texas Responsible Artificial Intelligence Governance Act signed into law", 24 Jun 2025.

[66] Office of the Governor of California, SB 53 signing, 29 Sep 2025; California Privacy Protection Agency, regulations approved 23 Sep 2025 (cppa.ca.gov/announcements/2025/20250923.html).

[67] Wiley, "New York finalizes RAISE Act for frontier AI models; law takes effect January 1, 2027".

[68] CMS, Interoperability and Prior Authorization Final Rule (CMS-0057-F), page modified 8 Oct 2026. cms.gov/initiatives/burden-reduction/.../cms-interoperability-prior-authorization-final-rule-cms-0057-f; HL7 Da Vinci PAS (hl7.org/fhir/us/davinci-pas/), CRD, DTR implementation guides.

[69] Epic on FHIR, "Request process" and open.epic FHIR interface list (write surface). fhir.epic.com/Documentation?docId=epiconfhirrequestprocess; open.epic.com/Interface/FHIR

[70] Oracle Health Millennium Platform APIs, R4 overview and DocumentReference (POST/PUT). docs.oracle.com/en/industries/health/millennium-platform-apis/mfrap/r4_overview.html

[71] Cohasset Associates, "Amazon S3 Object Lock compliance assessment" (SEC 17a-4(f), FINRA 4511(c), CFTC 1.31(c)–(d)). d1.awsstatic.com/r2018/b/S3-Object-Lock/Amazon-S3-Compliance-Assessment.pdf

[72] ClickHouse, "Delete mutations" (data is mutable; no native WORM). clickhouse.com/docs/concepts/features/operations/delete/delete-mutations

[73] Oracle NetSuite, REST web services documentation and 2026.1 release notes (token-based authentication closed to new integrations from 2027.1; PKCE mandatory; SOAP sunsetting).

[74] Okta, "Create a SAML app integration". developer.okta.com/docs/guides/create-an-app-

integration/saml2/main/

[75] AHIP/BCBSA prior-authorisation commitments, 23 Jun 2025 (Healio; NC Medical Society summaries).

For Nolvex
David Ngeiywa, Director
Date: 26 October 2026

Acknowledged for the Issuing Organization
Raphael Bosire
Date: _____